ESEN

C I B E R S E G U R I D A D

Proyecto Final · Entregable E.11

Documento final integrado: línea base de seguridad

Ejemplo resuelto de cátedra · Nexo Crítico Consultores · Energía Nacional S.A. de C.V. (ENSA)

Formato oficial del entregable E.11 de la Guía del Estudiante del Proyecto Final (2026), llenado íntegramente

Docente: Ing. Héctor Cuchilla

ESEN – CIBERSEGURIDAD – CICLO 03 – 2026

Tabla de contenidos

Registro formal del documento 3
1. Portada y datos generales 3
2. Introducción y compromiso de la dirección 3
3. Alcance del SGSI 4
4. BIA 4
5. Inventario y clasificación de activos 5
6. Matriz de riesgos y mapa de calor 5
7. Matriz RACI 6
8. Controles seleccionados (6) 6
8.1 Control CIS v8.1 n.° 12 — Gestión de la infraestructura de red 6
8.2 Control CIS v8.1 n.° 13 — Monitoreo y defensa de la red 6
8.3 Control CIS v8.1 n.° 6 — Gestión del control de acceso 6
8.4 Control CIS v8.1 n.° 7 — Gestión continua de vulnerabilidades 6
8.5 Control CIS v8.1 n.° 11 — Recuperación de datos 7
8.6 Control CIS v8.1 n.° 15 — Gestión de proveedores de servicios 7
9. Baseline según el IG asignado 7
10. Indicadores y auditoría interna 7
11. Roadmap de madurez 7
12. Conclusiones y recomendaciones al cliente 8
Verificación de trazabilidad de extremo a extremo 8
13. Bibliografía 9
Anexo A — Registro consolidado de supuestos 10
Anexo B — Retroalimentación aplicada 11
Anexo C — Anexos del BIA 11

Registro formal del documento

Campo	Registro
Organización (n.° y nombre del catálogo)	n.° 4 · Energía Nacional S.A. de C.V. (ENSA)
Grupo de Implementación asignado	IG3
Equipo consultor	Nexo Crítico Consultores (Equipo 04)
Versión y fecha	v1.0 · miércoles 11 de noviembre de 2026
Elaboró (oficial de documentación)	Paola Mena Quintanilla
Revisó (oficial de calidad)	Iván Cardoza Linares
Aprobó (consultor líder)	Alejandra Beltrán Rivas

Ejemplo resuelto de cátedra · entrega: miércoles 11 de noviembre de 2026 (H5) · evalúa J.2 completa (15 %). El documento integra los entregables E.02 a E.10 en su versión corregida tras la retroalimentación de cada hito, en las trece secciones y el orden fijo que define la Guía del Estudiante. Las tablas completas viven en los entregables y en los anexos; aquí se presentan sus resultados y las decisiones que los sostienen.

1. Portada y datos generales

Campo	Registro
Organización y sector	Energía Nacional S.A. de C.V. (ENSA), perfil n.° 4 del Catálogo de Empresas 2026 · energía y servicios públicos, 550 empleados
Grupo de Implementación asignado	IG3 · baseline de 153 salvaguardas de CIS Controls v8.1 (2024)
Equipo, integrantes y roles	Nexo Crítico Consultores (Equipo 04): Alejandra Beltrán Rivas, consultora líder · Diego Salguero Martínez, analista de riesgos y responsable del rol · Mariela Cortez Aguilar, analista de riesgos · Rodrigo Peña Escobar, arquitecto de controles · Paola Mena Quintanilla, oficial de documentación · Iván Cardoza Linares, oficial de calidad
Fecha de entrega	Miércoles 11 de noviembre de 2026
Versión del documento	v1.0
Anexos del informe	BIA_P01 a BIA_P07 (Anexo C) y los entregables E.01 a E.10 en su versión corregida

2. Introducción y compromiso de la dirección

ENSA distribuye energía eléctrica a clientes residenciales e industriales desde un centro de operaciones en San Salvador y subestaciones en todo el territorio, con 550 empleados. Su dependencia tecnológica es crítica: el perfil declara que un ciberataque exitoso puede causar un apagón de alcance nacional, y la indisponibilidad del servicio afecta a terceros ajenos a la empresa. Esa condición es la que sitúa a la organización en el Grupo de Implementación 3 y la que justifica que el baseline del programa sean las 153 salvaguardas completas de CIS Controls v8.1.

La dirección de ENSA declara la seguridad de la información y de la tecnología de operación como prioridad del negocio, en el mismo rango que la seguridad eléctrica de las personas; asigna a la Jefatura de Seguridad de la Información la autoridad para definir requisitos exigibles a TI y a TO y para detener cambios que introduzcan riesgo

no tratado; adopta CIS Controls v8.1 (2024) como marco de control operativo, ISO/IEC 27001:2022 como marco del sistema de gestión y NIST CSF 2.0 (2024) como lenguaje común de funciones; y compromete el presupuesto de USD 480 000 para 2027 y las tres plazas dedicadas que registra la ficha de datos del cliente, con revisión trimestral por la dirección. Los cinco objetivos de seguridad declarados —continuidad del telecontrol con RTO de dos horas, segmentación completa de los puntos de conexión TI–OT, autenticación multifactor en todo acceso administrativo y remoto, inventario completo de la red OT y notificación de las vulneraciones de datos personales dentro de las 72 horas del artículo 25 de la LPDP— se miden con los indicadores del programa y se ordenan en el tiempo con el roadmap, que arranca el lunes 4 de enero de 2027.

Firmante	Cargo	Firma	Fecha
Dirección general (simulada)	Ing. Óscar Mauricio Handal, Gerente General	(firma)	11 de noviembre de 2026
Responsable de seguridad de la información	Ing. Karla Beatriz Vásquez, Jefa de Seguridad de la Información	(firma)	11 de noviembre de 2026

3. Alcance del SGSI

El alcance cubre los cuatro procesos que el perfil declara críticos —operación de la red de control (SCADA/OT), medición inteligente (AMI), gestión de interrupciones (OMS) y sistema comercial y de facturación—, de los que el BIA confirmó como críticos al telecontrol y a la gestión de interrupciones y clasificó como importantes a la medición inteligente y al sistema comercial; tres procesos de soporte con efecto directo sobre ellos —gestión de TI corporativa, gestión de campo con GIS y atención al cliente—; y los tres procesos diferibles que el censo del BIA añadió, incorporados en la versión 1.1 de E.02. Comprende las seis unidades organizacionales del perfil y tres sedes: el centro de operaciones de San Salvador con su centro de control y su centro de datos, las doce subestaciones principales y el centro de atención comercial. Los sistemas incluidos son el SCADA de Siemens y su red de tecnología operacional, la cabecera de medición inteligente, el OMS, el SAP IS-U, el GIS, la red corporativa y, de forma explícita, los puntos de conexión entre la red OT y la red de TI que el perfil describe como inseguros.

Quedan excluidos, con justificación: la red inalámbrica de invitados, que no sostiene proceso alguno; la videovigilancia de subestaciones, gobernada aparte y con convergencia no resuelta hacia la red OT, que se registra como brecha B-07 y entra en la revisión anual; y los equipos de medición en poder del cliente, cuya custodia física corresponde al titular del servicio. Las partes interesadas son los clientes, el ente regulador del sector, el operador del sistema, los proveedores tecnológicos y el personal de campo. Los requisitos legales aplicables son la Ley para la Protección de Datos Personales (D.L. 144/2024), con la notificación de toda vulneración de datos personales en 72 horas que exige su artículo 25; la Ley de Ciberseguridad y Seguridad de la Información (D.L. 143/2024), registrada como requisito sujeto a que la Agencia de Ciberseguridad del Estado califique a ENSA como operador con incidencia en las infraestructuras críticas de la nación (art. 2); las obligaciones de continuidad y calidad del servicio de la Ley General de Electricidad y de las Normas de Calidad del Servicio de los Sistemas de Distribución de la SIGET, que registra la ficha de datos del cliente; y PCI DSS v4.0.1, que ENSA cumple por medio de la pasarela de pagos como comercio de nivel 2.

4. BIA

El análisis evaluó diez procesos con el método de trece pasos de la Guía del Estudiante del BIA (ISO 22301:2019, ISO/TS 22317:2021 y NIST SP 800-34 Rev. 1) y confirmó dos como críticos: el telecontrol de la red (P-01) y la gestión

de interrupciones (P-03). El sistema comercial y la medición inteligente, que el perfil declara críticos, resultaron importantes con 2,46: a las veinticuatro horas ninguna de sus calificaciones pasa de 3, y conservan su valoración económica porque la matriz de riesgos cuantifica con ella dos riesgos. La conclusión que gobierna el resto del proyecto es la distancia entre los procesos de tecnología de operación y los comerciales: el telecontrol tolera cuatro horas de interrupción y la facturación tolera setenta y dos.

Proceso	Puntaje	Clase	MTPD	RTO	WRT	RPO	Costo por hora	SLE
P-01 Operación de la Red de Control (SCADA/OT)	6,31	Crítico	4 h	2 h	1,5 h	15 min	USD 62 000	USD 4 950 000 (SLE-01)
P-03 Sistema de Gestión de Interrupciones (OMS)	4,62	Crítico	8 h	4 h	3 h	1 h	USD 18 500	USD 1 300 000 (SLE-02)
P-04 Sistema Comercial y de Facturación	2,46	Importante	72 h	24 h	24 h	4 h	USD 7 400	USD 1 395 000 (SLE-03) y USD 105 000 por exposición de datos (SLE-05)
P-02 Gestión de Medición Inteligente (AMI)	2,46	Importante	48 h	24 h	12 h	6 h	USD 2 900	USD 480 000 (SLE-04)

El análisis identificó ocho puntos únicos de falla y ocho brechas, con cuatro que exigen decisión inmediata: el respaldo del SCADA no sostiene los objetivos de recuperación declarados; los puntos de conexión TI–OT carecen de filtro documentado; el acceso remoto del proveedor del sistema de control opera sin multifactor ni registro; y no existe inventario ni monitoreo en la red OT. Los siete anexos BIA_P01 a BIA_P07 acompañan este informe (Anexo C) con el detalle del método, las fichas, la matriz de impacto, las dependencias, la priorización, los supuestos y el informe ejecutivo aprobado por la dirección simulada.

5. Inventario y clasificación de activos

El inventario reúne veinticuatro activos —información, software, hardware, servicios de terceros, personas clave e instalaciones—, y cada proceso crítico, y cada proceso importante que trata datos personales o tiene un punto único de falla, cuenta con al menos un activo de información, uno de plataforma y uno de personas o terceros. Los datos personales de clientes se clasifican como confidenciales por defecto y como restringidos cuando permiten inferir la ocupación de una vivienda, que es el caso de la curva de carga horaria de la medición inteligente; todos quedan marcados como sujetos a la LPDP. La configuración y la base de tiempo real del SCADA se clasifican como restringidas sin ser datos personales, porque su divulgación entrega el mapa de la operación de la red. Los veinticuatro activos aparecen en la matriz de riesgos.

6. Matriz de riesgos y mapa de calor

La matriz registra catorce riesgos valorados con escalas 1–5 de probabilidad e impacto: tres Críticos, diez Altos y uno Medio. Los tres Críticos son el ransomware que se propaga desde la red de TI al entorno de control (R-01), la manipulación de comandos por el acceso remoto del proveedor (R-02) y el compromiso de credenciales privilegiadas por phishing (R-07). Los ejes de amenaza activos del perfil aparecen de forma explícita —tecnología de operación, identidad, terceros y cadena de suministro, e inteligencia artificial—; el eje de nube se declara no aplicable porque el perfil no registra servicios en nube, y se reevaluará cuando se apruebe la migración del portal de clientes.

La cuantificación de los riesgos Críticos, con los valores de pérdida por evento único que entregó el BIA y la convención de estimación del proyecto para el ARO, arroja retornos de 698 % para la segmentación y el monitoreo, 1 963 % para el control del acceso remoto de proveedores y 896 % para la gestión de identidades; las tres recomendaciones se mantienen en los tres escenarios de sensibilidad. Una cuarta cuantificación, la del endurecimiento de los concentradores de medición, arroja un retorno negativo en el escenario esperado, y por eso la recomendación es absorberla en el control 4 del baseline. Tras el tratamiento, ningún riesgo conserva nivel superior a Medio, lo que satisface el apetito de riesgo que la dirección declaró y firmó.

7. Matriz RACI

La matriz asigna dieciocho actividades de seguridad sobre seis roles del organigrama de la ficha de datos del cliente, con la Jefatura de Seguridad de la Información que crea la ficha y cuya dependencia de la Gerencia General es el supuesto S-03. Cada fila tiene exactamente una A y al menos una R. Dos asignaciones merecen destacarse: la declaración de interrupción y el paso a operación manual tienen como aprobador al dueño del proceso —la Gerencia de Operaciones de Red—, porque es una decisión operativa con consecuencias sobre la seguridad de las personas; y la notificación de vulneraciones de datos personales tiene como aprobador a la Gerencia General, porque el plazo de 72 horas no admite delegación tácita.

8. Controles seleccionados (6)

Cada control se documenta en E.07 con su identificación, su política, su procedimiento operativo y sus controles técnicos, administrativos y físicos. Las políticas declaran reglas verificables —ninguna sesión se origina desde la red de TI hacia la red OT sin pasar por el anfitrión de salto; toda cuenta es nominal, incluidas las de soporte de proveedores; ninguna prueba de restauración se declara satisfactoria sin verificación funcional del dueño del proceso— y los procedimientos generan la evidencia que alimenta los indicadores.

8.1 Control CIS v8.1 n.° 12 — Gestión de la infraestructura de red

Trata R-01, R-03 y R-11. Corresponde a los controles 8.20, 8.21 y 8.22 de ISO/IEC 27002:2022 y a la función Proteger (PR.IR) de NIST CSF 2.0. De sus ocho salvaguardas, cinco se diseñan ahora y tres pasan al roadmap. Registra como hallazgo el fin de soporte de FortiOS 7.2 y lleva a E.10 la migración a FortiOS 7.4.

8.2 Control CIS v8.1 n.° 13 — Monitoreo y defensa de la red

Trata R-01, R-03 y R-10. Corresponde a los controles 8.16, 8.20 y 8.22 de ISO/IEC 27002:2022 y a la función Detectar (DE.CM). De sus once salvaguardas, cinco se diseñan ahora y seis pasan al roadmap.

8.3 Control CIS v8.1 n.° 6 — Gestión del control de acceso

Trata R-02, R-07 y R-09. Corresponde a los controles 5.15, 5.17, 5.18 y 8.5 de ISO/IEC 27002:2022 y a la función Proteger (PR.AA). De sus ocho salvaguardas, seis se diseñan ahora y dos pasan al roadmap.

8.4 Control CIS v8.1 n.° 7 — Gestión continua de vulnerabilidades

Trata R-12, con efecto sobre R-01 y R-04. Corresponde a los controles 8.8 y 8.32 de ISO/IEC 27002:2022 y a las funciones Identificar (ID.RA) y Proteger (PR.PS). Sus siete salvaguardas se diseñan ahora. Registra como hallazgo el fin de soporte de Windows 10 22H2 en el parque heredado y lleva a E.10 su sustitución por Windows 11.

8.5 Control CIS v8.1 n.° 11 — Recuperación de datos

Trata R-06 y reduce el impacto de R-01. Corresponde a los controles 8.13 y 5.29 de ISO/IEC 27002:2022 y a la función Recuperar (RC.RP). Sus cinco salvaguardas se diseñan ahora.

8.6 Control CIS v8.1 n.° 15 — Gestión de proveedores de servicios

Trata R-09, R-02 y R-14. Corresponde a los controles 5.19 a 5.22 de ISO/IEC 27002:2022 y a la función Gobernar (GV.SC). De sus siete salvaguardas, cinco se diseñan ahora y dos pasan al roadmap.

9. Baseline según el IG asignado

Las 107 salvaguardas que quedan fuera de los seis controles desarrollados se mapean una por una con su medida, su estado y su evidencia. El resultado: una existente, trece existentes parciales, diecisiete cubiertas por tercero, sesenta y dos por implementar y catorce al roadmap. La única existente es la 9.1, navegador y cliente de correo soportados, que la ficha de datos del cliente registra entre los controles que ya existen. El conteo de cierre queda verificado: 41 salvaguardas IG1 en el checklist más 15 en las tablas F.1 de los seis controles suman las 56 de la higiene cibernética esencial, y 107 más 46 suman las 153 del Grupo de Implementación asignado. Las salvaguardas cubiertas por tercero nombran proveedor, cláusula contractual y evidencia exigible, porque la responsabilidad se traslada con un contrato y la obligación de verificarla permanece en ENSA.

10. Indicadores y auditoría interna

El programa declara doce indicadores, dos por cada control desarrollado, alimentados por la evidencia que genera cada procedimiento. Tres tienen meta del 100 % sin tolerancia —cuentas privilegiadas con segundo factor, sesiones de proveedor dentro de ventana y pruebas de restauración dentro del RTO—, porque cada uno corresponde a un riesgo Crítico y una sola excepción reabre la condición que lo hizo Crítico. La auditoría interna propuesta cubre los seis controles y los procesos P-01 y P-04, con criterios en CIS v8.1, ISO/IEC 27001:2022 §§ 7.5, 8 y 9, ISO/IEC 27002:2022 y la LPDP; se ejecuta del 9 al 20 de marzo de 2027 con un auditor independiente de las áreas auditadas, y sus no conformidades generan acciones correctivas que la revisión trimestral por la dirección sigue y que el roadmap incorpora.

11. Roadmap de madurez

El roadmap ordena veintinueve iniciativas en tres horizontes contados desde el arranque del programa, el lunes 4 de enero de 2027: trece en el corto plazo, que cierran 60 salvaguardas, con USD 392 000 cotizados en nueve de ellas; once en el mediano, que cierran 57, con USD 265 000 cotizados en ocho; y cinco en el largo, que cierran las 18 restantes con USD 180 000. Hoy operan 18 salvaguardas; al cierre del corto plazo operan 78, al del mediano 135 y al del largo las 153 (tabla I.2 de E.10). La inversión cotizada del primer año cabe en el presupuesto comprometido por la dirección; la migración a FortiOS 7.4 y la sustitución de Windows 10, hallazgos de fin de soporte de E.07, se cotizan antes de iniciarlas. Dos iniciativas fuera del conteo de las 153 tratan la parte física del riesgo R-11 con los controles 7.2, 7.4 y 7.11 de ISO/IEC 27002:2022 (tabla I.3). El orden del corto plazo lo decide la dependencia técnica: el respaldo del entorno SCADA encabeza el programa porque sin él cualquier incidente excede el período máximo tolerable, y la segmentación le sigue porque habilita técnicamente al monitoreo, que por eso aparece en el mediano plazo.

12. Conclusiones y recomendaciones al cliente

El estado de riesgo de ENSA se explica por una sola condición estructural: la convergencia entre la red de TI y la red de tecnología operacional existe de hecho y carece de gobierno. El perfil de la organización lo reconoce al describir un aislamiento que no es real, y el análisis lo confirma: los tres riesgos Críticos y siete de los diez Altos tienen su origen o su vía de propagación en esa frontera. Su tratamiento exige decisión, presupuesto y disciplina de operación, con tecnología disponible en el mercado.

Seis medidas prioritarias, en este orden: (1) implantar el respaldo del entorno SCADA con copia aislada e inmutable y prueba trimestral de restauración, porque es la brecha que hoy impide cumplir el objetivo de recuperación de dos horas; (2) segmentar los puntos de conexión TI–OT con zona intermedia, anfitrión de salto y reglas con vencimiento; (3) someter el acceso remoto de proveedores a cuentas nominales, autenticación multifactor y grabación de sesión, con la cláusula contractual que lo haga exigible; (4) desplegar autenticación multifactor en toda cuenta administrativa y capacitar al personal frente a la suplantación asistida por inteligencia artificial; (5) inventariar la red OT con descubrimiento pasivo y desplegar detección en esa red; y (6) documentar la configuración del SCADA, formar un segundo ingeniero y contratar respuesta del fabricante en cuatro horas, que es la medida de menor costo y mayor efecto sobre el tiempo de recuperación.

La ruta hacia el IG3 completo abarca treinta y seis meses, del 4 de enero de 2027 al 31 de diciembre de 2029, con USD 837 000 de inversión cotizada más la migración a FortiOS 7.4 y la sustitución de Windows 10, que se cotizan antes de iniciarlas. Al cierre del corto plazo ningún riesgo Crítico o Alto conserva su nivel inherente; al cierre del largo plazo, ENSA completa las 153 salvaguardas del Grupo de Implementación que su perfil de riesgo exige. Dos decisiones quedan solicitadas a la dirección para el primer trimestre del programa: validar la duración máxima sostenible del procedimiento alterno de operación manual, que la ficha estima en 12 horas y el simulacro de marzo de 2026 sostuvo 8, porque si el valor real se acerca a las ocho horas el período máximo tolerable debe revisarse a la baja; y renegociar el anexo de seguridad del contrato del fabricante del sistema de control, del que dependen tres de las medidas prioritarias.

Verificación de trazabilidad de extremo a extremo

Comprobación	Resultado
Cada proceso crítico del BIA sostiene activos del inventario	Los dos procesos críticos y los cinco importantes tienen activos declarados; los tres diferibles declaran su ausencia motivada
Cada activo del inventario aparece en la matriz de riesgos	Los veinticuatro activos están referenciados en al menos un riesgo
Cada punto único de falla o brecha del BIA entra como vulnerabilidad	Los doce trasladados en la tabla B.4 aparecen en la matriz de E.05
Cada riesgo Crítico o Alto tiene control desarrollado o salvaguarda del baseline	Los trece riesgos Crítico o Alto están cubiertos; el riesgo Medio también
Cada control de la sección 8 nombra riesgos de la sección 6	Los seis controles declaran sus riesgos en su tabla F.1
Cada indicador de la sección 10 mide un control de la sección 8	Doce indicadores, dos por control
Cada salvaguarda que no opera hoy tiene iniciativa en el roadmap	Las veintinueve iniciativas cierran las 135 salvaguardas que no operan hoy: 89 del checklist y 46 de las tablas F.1

Comprobación	Resultado
Cada supuesto tiene identificador global y ningún dato de la ficha figura como supuesto	S-01 a S-17 en el Anexo A; los siete identificadores sin uso se conservan con la cita de la ficha

13. Bibliografía

- Center for Internet Security. *CIS Critical Security Controls, versión 8.1*. Estados Unidos: CIS, 2024.
- Center for Internet Security. *CIS Benchmarks* de Fortinet FortiGate 7.4.x, Microsoft Windows 11 Enterprise, Microsoft Windows 10 Enterprise, Red Hat Enterprise Linux 8, SUSE Linux Enterprise 15 y Oracle Database 19c, en la versión vigente a la fecha de este documento.
- International Organization for Standardization / International Electrotechnical Commission. *ISO/IEC 27001:2022 — Sistemas de gestión de la seguridad de la información. Requisitos*. Ginebra: ISO, 2022.
- International Organization for Standardization / International Electrotechnical Commission. *ISO/IEC 27002:2022 — Controles de seguridad de la información*. Ginebra: ISO, 2022.
- International Organization for Standardization. *ISO 22301:2019 — Sistemas de gestión de la continuidad del negocio. Requisitos*. Ginebra: ISO, 2019.
- International Organization for Standardization. *ISO/TS 22317:2021 — Directrices para el análisis de impacto en el negocio*, segunda edición. Ginebra: ISO, 2021.
- National Institute of Standards and Technology. *The NIST Cybersecurity Framework (CSF) 2.0*. Gaithersburg: NIST, 2024.
- National Institute of Standards and Technology. *SP 800-30 Rev. 1 — Guide for Conducting Risk Assessments*. Gaithersburg: NIST, 2012.
- National Institute of Standards and Technology. *SP 800-34 Rev. 1 — Contingency Planning Guide for Federal Information Systems*. Gaithersburg: NIST, 2010.
- PCI Security Standards Council. *Payment Card Industry Data Security Standard (PCI DSS)*, versión 4.0.1. 2024.
- Asamblea Legislativa de la República de El Salvador. *Ley para la Protección de Datos Personales*, Decreto Legislativo 144, Diario Oficial del 15 de noviembre de 2024.
- Asamblea Legislativa de la República de El Salvador. *Ley de Ciberseguridad y Seguridad de la Información*, Decreto Legislativo 143, Diario Oficial del 15 de noviembre de 2024.
- Superintendencia General de Electricidad y Telecomunicaciones (SIGET). *Normas de Calidad del Servicio de los Sistemas de Distribución*.
- The Open Group. *Risk Taxonomy (O-RT) versión 3.0.1 y Risk Analysis (O-RA) versión 2.0.1*. 2021.
- Escuela Superior de Economía y Negocios. *Catálogo de Empresas del Proyecto Final, ciclo 03-2026*, perfil n.° 4: Energía Nacional S.A. de C.V., con su ficha de datos del cliente.

Anexo A — Registro consolidado de supuestos

ID	Supuesto	Fundamento u origen	Entregable que lo declaró
S-01	El acta se entrega el 25 de septiembre con las tres preferencias y se actualiza a la versión 1.1 con la organización asignada, la fecha de asignación y las firmas	Calendario del proyecto: el registro de asignaciones se publica el lunes 28 de septiembre	E.01
S-02	Los nombres, carnés y correos de los integrantes son ficticios	Ejemplo de cátedra con un equipo de muestra	E.01
S-03	La Jefatura de Seguridad de la Información que la ficha crea con tres plazas depende de la Gerencia General	La ficha crea la jefatura y sus plazas sin fijar a quién reporta	E.01 y E.02
S-04	Sin uso: las obligaciones de continuidad y calidad del servicio son un dato de la ficha	Identificador conservado para la numeración global	E.02
S-05	Sin uso: el presupuesto de USD 480 000 y las tres plazas son un dato de la ficha	Identificador conservado para la numeración global	E.02
S-06	Sin uso: las doce subestaciones principales son un dato de la ficha, con un rango de 8 a 20	Identificador conservado para la numeración global	E.02, E.03 y BIA_P06
S-07	Entrevistas, participantes y fechas del levantamiento del BIA	El perfil no describe personas ni reuniones	BIA_P01, BIA_P06 y E.03
S-08	Sin uso: los USD 38 000 por hora de ingresos no percibidos se derivan de la ficha (190 MW × USD 200 por MWh)	Identificador conservado para la numeración global	BIA_P06 y E.03
S-09	Sin uso: las compensaciones de USD 4 500 por hora a clientes industriales son un dato de la ficha	Identificador conservado para la numeración global	BIA_P06 y E.03
S-10	Sin uso: el AV de USD 9 000 000 del proceso de control de red se deriva de la ficha (USD 6,0 M de margen más USD 3,0 M de reposición)	Identificador conservado para la numeración global	BIA_P06 y E.03
S-11	A igual puntaje decide el mayor costo de indisponibilidad por hora	Aplicado a P-04 y P-02, ambos con 2,46	BIA_P05, BIA_P06 y E.03
S-12	EF de 0,55 en el evento de referencia sobre el SCADA, entre 0,40 y 0,70	Criterio del dueño del proceso con el costo por día	BIA_P06 y E.03
S-13	Sin uso: la duración máxima sostenible del procedimiento alterno, 12 horas entre 8 y 16, es un dato de la ficha	Identificador conservado para la numeración global	BIA_P06 y E.03
S-14	Presupuesto de seguridad de 2028 y 2029 igual al de 2027, entre USD 300 000 y 600 000	La ficha deja esos dos años sujetos a aprobación de la Junta Directiva	BIA_P06 y E.03

ID	Supuesto	Fundamento u origen	Entregable que lo declaró
S-15	Soluciones Ánfora S.A. de C.V. desarrolla y mantiene el portal de clientes bajo el contrato MSA-2025-014	El perfil y la ficha no dicen quién desarrolla el portal	E.08
S-16	Vector Security S.A. de C.V. ejecuta las pruebas de penetración bajo el contrato SVC-2026-003	La ficha no declara capacidad interna de pruebas ofensivas	E.08
S-17	El contrato de soporte del fabricante del SCADA es el SOP-2024-007 y admite el anexo de seguridad en su renovación	La ficha menciona el contrato anual sin su instrumento	E.08

Anexo B — Retroalimentación aplicada

Hito	Retroalimentación recibida	Cambio aplicado	Sección afectada
H1 (E.01, E.02)	Sin retroalimentación recibida	La versión 1.1 del acta, entregada con E.02 el 2 de octubre, y la versión 1.1 de E.02 con la sección A.3, entregada con E.03 el 16 de octubre, responden al calendario del proyecto	Secciones 2 y 3
H2 (E.03, E.04)	Sin retroalimentación recibida	Las versiones 1.1 de E.03, E.04 y BIA_P07 (secciones 8 a 11) se entregan con E.05 el 23 de octubre, según el calendario	Secciones 4 y 5
H3 (E.05, E.06)	Sin retroalimentación recibida	—	—
H4 (E.07, E.08, E.09)	Sin retroalimentación recibida	—	—

El ejemplo de cátedra no recibió retroalimentación en los hitos; las versiones 1.1 que registra la tabla son las que fija el calendario del proyecto.

Anexo C — Anexos del BIA

Los siete anexos se adjuntan al final del PDF en su versión final; esta tabla los lista en el DOCX.

Anexo	Versión	Páginas en el PDF final
BIA_P01 Inventario de procesos	v1.0	13 a 18
BIA_P02 Fichas BIA de los procesos críticos	v1.0	19 a 29
BIA_P03 Matrices de impacto	v1.0	30 a 36
BIA_P04 Mapas de dependencias	v1.0	37 a 42
BIA_P05 Matriz de criticidad	v1.0	43 a 49
BIA_P06 Supuestos, puntos únicos de falla y brechas	v1.0	50 a 56

Anexo	Versión	Páginas en el PDF final
BIA_P07 Informe ejecutivo	v1.1, con las secciones 8 a 11 entregadas junto con E.05	57 a 66

ESEN

CIBERSEGURIDAD

Inventario de procesos de negocio

El universo del análisis de impacto

Ejemplo resuelto de cátedra · Nexo Crítico Consultores · Energía Nacional S.A. de C.V. (ENSA)

Análisis de Impacto en el Negocio · Plantilla 01 de 07

ISO 22301:2019 · ISO/TS 22317:2021 · NIST SP 800-34 Rev. 1

Docente: Ing. Héctor Cuchilla

ESEN – CIBERSEGURIDAD – CICLO 03 – 2026

Tabla de contenidos

1. Identificación del trabajo..... 3
2. Cómo se llena..... 3
3. Inventario..... 4
4. Alcance declarado y exclusiones..... 5
5. Glosario de los campos de esta plantilla..... 6
Método de levantamiento empleado en el censo..... 6

Ejemplo resuelto de cátedra · Nexo Crítico Consultores · anexo 1 de 7 del BIA que se entrega con E.03.

1. Identificación del trabajo

Esta plantilla se llena por equipo y sobre la empresa que el equipo tiene asignada en el catálogo del Proyecto Final. El caso resuelto que la Guía del Estudiante desarrolla usa la Red Hospitalaria Metropolitana; cada equipo aplica el mismo método a su propia empresa.

Campo	Contenido
Empresa del catálogo del Proyecto Final	Energía Nacional S.A. de C.V. (ENSA), perfil n.° 4
Sector y tamaño declarados en el perfil	Energía y servicios públicos · mediana, 550 empleados
Equipo (número y nombre)	Equipo 04 · Nexo Crítico Consultores
Integrantes	A. Beltrán Rivas, D. Salguero Martínez, M. Cortez Aguilar, R. Peña Escobar, P. Mena Quintanilla, I. Cardoza Linares
Analista responsable de esta plantilla	Mariela Cortez Aguilar, analista de riesgos
Fecha de elaboración	6 de octubre de 2026
Versión del documento	v1.0

2. Cómo se llena

El trabajo empieza por enumerar procesos, no sistemas. Un proceso de negocio se describe por lo que produce para alguien: la admisión de un paciente, la emisión de una factura, la entrega de un resultado de laboratorio. Lo que no entra en este inventario no se analiza, y lo que no se analiza no se protege.

- **Proceso:** nombre en lenguaje de negocio, con un verbo y su objeto.
- **Área responsable:** unidad organizativa que lo ejecuta.
- **Dueño del proceso:** nombre y cargo de quien responde por él y firma la ficha BIA.
- **Servicio que entrega:** el producto o servicio concreto que resulta del proceso.
- **Destinatario:** quién lo recibe, sea un cliente externo o un área interna.
- **Sistemas de soporte:** aplicaciones y plataformas sin las cuales el proceso no opera.
- **Ventana de operación:** horario y días en que el proceso debe estar disponible.

3. Inventario

N.º	Proceso	Área	Dueño (nombre y cargo)	Servicio que entrega	Destinatario	Sistemas de soporte	Ventana de operación
P-01	Operación de la Red de Control (SCADA/OT)	Gerencia de Operaciones de Red	Ing. René Alfaro, Gerente de Operaciones de Red	Monitoreo y control en tiempo real de la red de distribución: maniobras, reconexión y supervisión de subestaciones	Clientes residenciales e industriales; operador del sistema	SCADA Siemens, red OT, enlaces con las doce subestaciones principales, radio troncalizado	24 × 7, sin ventana de detención
P-02	Gestión de Medición Inteligente (AMI)	Gerencia Técnica	Ing. Sonia Portillo, Gerente Técnica	Recolección y procesamiento de datos de consumo de medidores inteligentes	Sistema comercial, clientes, Gerencia Comercial	Cabecera AMI, concentradores de datos, red de comunicación de medidores	24 × 7 con cierre de ciclo diario a las 02:00
P-03	Sistema de Gestión de Interrupciones (OMS)	Gerencia de Operaciones de Red	Ing. René Alfaro, Gerente de Operaciones de Red	Registro, despacho y restauración del servicio durante apagones	Clientes afectados, cuadrillas de campo, ente regulador	OMS, GIS, SCADA, centro de contacto, radio troncalizado	24 × 7, con picos en temporada de lluvias
P-04	Sistema Comercial y de Facturación	Gerencia Comercial	Lic. Marta Rodríguez, Gerente Comercial	Procesamiento de lecturas, tarifación, emisión de facturas y gestión de cobro	Cientos de miles de clientes; Finanzas	SAP IS-U, portal de clientes, pasarela de pagos, AMI	Lunes a sábado, 06:00–22:00; cierre de ciclo mensual
P-05	Atención al cliente y centro de contacto	Gerencia Comercial	Lic. Marta Rodríguez, Gerente Comercial	Recepción de avisos de falla, reclamos y solicitudes de servicio	Clientes	Plataforma de centro de contacto, OMS, SAP IS-U	Lunes a domingo, 06:00–22:00; 24 × 7 en contingencia
P-06	Gestión de campo y cuadrillas con GIS	Gerencia Técnica	Ing. Sonia Portillo, Gerente Técnica	Asignación, seguimiento y cierre de órdenes de trabajo en la red	Cuadrillas, Operaciones de Red	GIS, aplicación móvil de cuadrillas, OMS	Lunes a sábado, 06:00–18:00; guardias 24 × 7
P-07	Compras y contratación de terceros	Finanzas	Lic. Julio Menéndez, Gerente de Finanzas	Adquisición de bienes y contratación de servicios técnicos	Todas las gerencias; proveedores	ERP financiero, repositorio de contratos	Lunes a viernes, 08:00–17:00
P-08	Nómina y administración de personal	Finanzas	Lic. Julio Menéndez, Gerente de Finanzas	Pago de planilla, control de asistencia y gestión del personal	Empleados; entidades previsionales	ERP financiero, control de asistencia	Lunes a viernes, 08:00–17:00; cierre quincenal

N.º	Proceso	Área	Dueño (nombre y cargo)	Servicio que entrega	Destinatario	Sistemas de soporte	Ventana de operación
P-09	Gestión de TI corporativa (identidad, correo y ofimática)	TI/TO	Ing. Carlos Iraheta, Jefe de TI/TO	Servicios de identidad, correo, archivos y puesto de trabajo	Todas las gerencias	Directorio corporativo, correo, servidores de archivos, estaciones de trabajo	Lunes a domingo, 24 × 7 con soporte 07:00–19:00
P-10	Contabilidad y reportes regulatorios	Finanzas	Lic. Julio Menéndez, Gerente de Finanzas	Cierre contable y reportes de calidad y continuidad del servicio al ente regulador	Dirección, ente regulador	ERP financiero, OMS (datos de interrupciones)	Lunes a viernes, 08:00–17:00; cierre mensual

El censo parte de los procesos cubiertos por el alcance declarado en E.02 y añade los procesos de soporte que la entrevista con la Gerencia General identificó como habilitantes. Los cuatro primeros son los que el perfil del catálogo declara como críticos; su clase la decide el puntaje de BIA_P05, que confirma como críticos a P-01 y P-03 y clasifica como importantes a P-02 y P-04.

4. Alcance declarado y exclusiones

Registrar qué procesos quedan fuera del análisis y por qué. Una exclusión declarada es una decisión; una exclusión silenciosa es un hallazgo de auditoría.

El inventario cubre las seis unidades organizacionales del perfil y las tres sedes del alcance: centro de operaciones de San Salvador con el centro de control y el centro de datos corporativo, las doce subestaciones principales y el centro de atención comercial. Quedan fuera, con la misma justificación que E.02: la red inalámbrica de invitados, que no sostiene proceso alguno; los sistemas de videovigilancia de subestaciones, que se gobiernan aparte y entran en la revisión anual; y los equipos de medición en poder del cliente, cuya custodia física corresponde al titular del servicio. La exclusión de la videovigilancia se registra como brecha en BIA_P06 porque su convergencia con la red OT no está resuelta.

5. Glosario de los campos de esta plantilla

Término	Definición
Proceso de negocio	Conjunto de actividades que produce un servicio o producto identificable para un destinatario.
Dueño del proceso	Persona con autoridad para declarar las métricas de tiempo del proceso y responder por ellas.
Ventana de operación	Franja horaria y de calendario en que el proceso debe estar disponible para su destinatario.
Sistema de soporte	Aplicación, plataforma o servicio tecnológico sin el cual el proceso no puede ejecutarse en su forma normal.

Método de levantamiento empleado en el censo

Medio de levantamiento	Empleado (Sí/No)	Participantes	Fecha
Entrevista estructurada con el dueño del proceso	Sí	Gerente de Operaciones de Red, Gerente Técnica, Gerente Comercial, Gerente de Finanzas, Jefe de TI/TO	29 y 30 de septiembre de 2026
Cuestionario estandarizado	Sí	Dueños de los diez procesos del censo	1 de octubre de 2026
Taller con áreas interdependientes	Sí	Operaciones de Red, Técnica, Comercial y TI/TO	2 de octubre de 2026
Revisión documental de registros y contratos	Sí	Contratos de soporte SCADA y AMI; bitácoras de interrupciones	2 y 3 de octubre de 2026
Validación firmada por el dueño del proceso	Sí	Los cinco dueños de proceso	3 de octubre de 2026
Aprobación de la dirección	Sí	Gerencia General	6 de octubre de 2026

Las entrevistas, los participantes y las fechas son supuestos declarados del ejercicio (S-07): el perfil del catálogo no describe personas ni reuniones, y el método del BIA exige declarar de dónde sale cada dato. El equipo mantiene la coherencia de estos nombres en los siete anexos y en E.03.

ESEN

CIBERSEGURIDAD

Ficha BIA por proceso

Métricas de tiempo, costo de indisponibilidad y valoración

Ejemplo resuelto de cátedra · Nexo Crítico Consultores · Energía Nacional S.A. de C.V. (ENSA)

Análisis de Impacto en el Negocio · Plantilla 02 de 07

ISO 22301:2019 · ISO/TS 22317:2021 · NIST SP 800-34 Rev. 1

Docente: Ing. Héctor Cuchilla

ESEN – CIBERSEGURIDAD – CICLO 03 – 2026

Tabla de contenidos

1. Identificación del trabajo..... 3
2. Método de levantamiento empleado..... 3
3. Identificación del proceso analizado..... 4
4. Métricas de tiempo..... 4
5. Nivel mínimo de servicio durante la contingencia (MBCO)..... 5
6. Períodos pico y estacionalidad..... 6
7. Procedimiento alterno y duración máxima sostenible..... 6
8. Costo de indisponibilidad por hora y por día..... 7
9. Valoración económica que el BIA entrega..... 7
10. Método de valoración empleado..... 9
11. Validación..... 9
12. Glosario de los campos de esta plantilla..... 10
Ficha resumida del otro proceso crítico y valoración de los procesos importantes con SLE..... 10

Ejemplo resuelto de cátedra · anexo 2 de 7. La ficha completa corresponde al proceso P-01, Operación de la Red de Control (SCADA/OT); la ficha del otro proceso crítico (P-03) y la valoración de los dos procesos importantes que conservan su SLE (P-04 y P-02) se resumen al final con las mismas variables.

1. Identificación del trabajo

Esta plantilla se llena por equipo y sobre la empresa que el equipo tiene asignada en el catálogo del Proyecto Final. El caso resuelto que la Guía del Estudiante desarrolla usa la Red Hospitalaria Metropolitana; cada equipo aplica el mismo método a su propia empresa.

Campo	Contenido
Empresa del catálogo del Proyecto Final	Energía Nacional S.A. de C.V. (ENSA), perfil n.° 4
Sector y tamaño declarados en el perfil	Energía y servicios públicos · mediana, 550 empleados
Equipo (número y nombre)	Equipo 04 · Nexo Crítico Consultores
Integrantes	Seis integrantes con los cinco roles cubiertos
Analista responsable de esta plantilla	Diego Salguero Martínez, analista de riesgos (responsable del rol)
Fecha de elaboración	8 de octubre de 2026
Versión del documento	v1.0

2. Método de levantamiento empleado

Los datos del análisis de impacto viven en quien opera el proceso, y el analista los extrae con un método declarado. Marcar los medios utilizados y registrar la validación, porque una ficha sin validación del dueño del proceso carece de valor probatorio.

Medio de levantamiento	Empleado (Sí/No)	Participantes	Fecha
Entrevista estructurada con el dueño del proceso	Sí	Ing. René Alfaro, Gerente de Operaciones de Red; Ing. Carlos Iraheta, Jefe de TI/TO	7 de octubre de 2026
Cuestionario estandarizado	Sí	Dos operadores del centro de control y un ingeniero de subestaciones	7 de octubre de 2026
Taller con áreas interdependientes	Sí	Operaciones de Red, Técnica y TI/TO	8 de octubre de 2026
Revisión documental de registros y contratos	Sí	Contrato de soporte del fabricante SCADA; bitácora de maniobras de los últimos doce meses	8 de octubre de 2026
Validación firmada por el dueño del proceso	Sí	Ing. René Alfaro	8 de octubre de 2026
Aprobación de la dirección	Sí	Ing. Óscar Mauricio Handal, Gerente General	12 de octubre de 2026

3. Identificación del proceso analizado

Se llena una ficha completa por cada proceso que resulta crítico en la precalificación de BIA_P05 (corte de 24 horas); el proceso importante que trata los datos personales que cuantifica la ficha de datos del cliente llena además las secciones 3, 8 y 9. Toda cifra que no proviene de la ficha de datos del cliente es un supuesto declarado, con su identificador global S-nn, hasta que el dueño del proceso la valida con su firma.

Campo	Contenido
Proceso analizado	Operación de la Red de Control (SCADA/OT)
Código del proceso (del inventario)	P-01
Área responsable	Gerencia de Operaciones de Red
Dueño del proceso (nombre y cargo)	Ing. René Alfaro, Gerente de Operaciones de Red
Servicio que entrega y destinatario	Monitoreo y control en tiempo real de la red de distribución —maniobras, reconexión y supervisión de subestaciones— para los clientes residenciales e industriales y para el operador del sistema
Sistemas de soporte	SCADA Siemens (servidores de adquisición, servidores de aplicación y estaciones HMI del centro de control), red de tecnología operacional, enlaces de comunicación con las doce subestaciones principales, radio troncalizado como medio alterno
Ventana de operación	24 × 7 los 365 días, sin ventana de detención programada

4. Métricas de tiempo

El período máximo tolerable de interrupción lo fija el negocio, nunca el área de tecnología, y todas las demás métricas se acomodan por debajo de él. El objetivo de tiempo de recuperación y el objetivo de punto de recuperación se determinan por separado: uno gobierna la capacidad de restauración y el otro la frecuencia del respaldo.

Métrica	Valor declarado	Unidad	Quién lo declara y con qué fundamento
MTPD / MTD — período máximo tolerable de interrupción	4	horas	Gerente de Operaciones de Red: a partir de la cuarta hora sin telecontrol la operación manual no sostiene la reconfiguración de la red ante una falla y la indisponibilidad alcanza a terceros. Deriva del cruce del umbral en BIA_P03
RTO — objetivo de tiempo de recuperación	2	horas	Gerente de Operaciones de Red y Jefe de TI/TO: plazo para restablecer los servidores de adquisición y la comunicación con las subestaciones desde el respaldo del sistema SCADA
WRT — tiempo de recuperación del trabajo	1,5	horas	Operadores del centro de control: verificación de señales, reconciliación de estados de interruptores y retorno del control automático tras la operación manual

Métrica	Valor declarado	Unidad	Quién lo declara y con qué fundamento
RPO — objetivo de punto de recuperación	15	minutos	Jefe de TI/TO: frecuencia máxima admisible entre respaldos de la base de datos de tiempo real y de la configuración del sistema
MBCO — objetivo mínimo de continuidad del negocio	Operación manual de las doce subestaciones principales	descripción	Gerente de Operaciones de Red: supervisión y maniobra local con personal en sitio y comunicación por radio troncalizado, con capacidad para atender fallas aisladas y sin reconfiguración automática de la red

Comprobación de coherencia obligatoria: RTO + WRT ≤ MTPD

RTO declarado: _____ + WRT declarado: _____ = _____ ≤ MTPD declarado: _____

Resultado de la comprobación (Cumple / No cumple): _____

Si la comprobación no se cumple, la ficha no avanza: se corrige el RTO, se corrige el WRT o se justifica ante la dirección un MTPD mayor.

Comprobación obligatoria: RTO + WRT ≤ MTPD → 2 + 1,5 = 3,5 ≤ 4. La ficha cumple con media hora de margen, que el equipo declara deliberadamente estrecha y que sostiene la prioridad del control 11 en el roadmap.

5. Nivel mínimo de servicio durante la contingencia (MBCO)

El objetivo mínimo de continuidad declara qué parte del proceso vuelve primero y con qué capacidad, mientras la recuperación completa avanza. Describir la operación reducida en términos verificables: qué se atiende, con qué volumen y con qué personal.

Durante la contingencia, ENSA mantiene la supervisión y la maniobra de las doce subestaciones principales con personal desplazado en sitio y comunicación por radio troncalizado. El nivel mínimo aceptado es: atención de fallas

aisladas con maniobra local, sin reconfiguración automática de la red, sin telecontrol de los equipos de las líneas secundarias y con registro manual de eventos en formulario impreso para su reintroducción posterior. Se requieren doce operadores de campo en turno —uno por subestación—, dos coordinadores en el centro de control y los enlaces de radio operativos. El nivel mínimo no cubre la operación de la red inteligente ni la respuesta a una falla múltiple simultánea: esa es la razón por la que el MTPD es de cuatro horas y no mayor.

6. Períodos pico y estacionalidad

El mismo proceso interrumpido produce daños distintos según el momento del año. La planificación de continuidad se dimensiona para el peor escenario temporal, no para el promedio.

Período pico	Fechas o condiciones	Factor de agravamiento respecto del promedio	Escenario temporal usado en la valoración
Temporada de lluvias y tormentas eléctricas	Mayo a octubre, con concentración en junio y septiembre	2,2 × en número de fallas simultáneas y 1,6 × en costo por hora	Sí: la valoración usa el escenario de temporada de lluvias
Demanda máxima diaria	Días hábiles, 18:00 a 21:00	1,4 × en clientes afectados por hora de indisponibilidad	Considerado dentro del escenario anterior
Mantenimiento mayor de subestaciones	Enero a marzo, ventanas programadas	1,3 × por menor redundancia disponible durante la maniobra	No: se documenta y se descarta por ser planificado
Cierre de ciclo comercial	Último día hábil del mes	Sin efecto sobre este proceso	No

7. Procedimiento alterno y duración máxima sostenible

La duración máxima sostenible es el dato que suele faltar: cuántas horas o días puede la organización operar en modo alterno antes de que el volumen acumulado desborde al personal, la calidad se degrade o la reconstrucción posterior se vuelva impracticable. Esa duración es la que alarga el MTPD del proceso, y por eso se declara y se verifica.

Campo	Contenido
Descripción del procedimiento alterno	Operación manual: se despliega personal a las doce subestaciones principales, la supervisión se hace con instrumentos locales, las maniobras se ordenan por radio troncalizado desde el centro de control y cada evento se registra en el formulario impreso F-OP-12
Quién lo ejecuta	Operadores de campo de la Gerencia de Operaciones de Red, coordinados por el jefe de turno del centro de control
Recursos que exige (personas, formularios, equipos)	Doce operadores por turno más dos coordinadores; radios troncalizados con batería de respaldo; formularios impresos; vehículos de la flota técnica; llaves y permisos de acceso a subestación
Duración máxima sostenible	12 horas continuas, con un solo relevo de turno disponible
Cómo se verificó esa duración	Entrevista con el dueño del proceso y revisión de la bitácora del simulacro de operación manual de marzo de 2026, que se sostuvo ocho horas con relevo completo

Campo	Contenido
Esfuerzo de reconstrucción posterior (alimenta el WRT)	Reintroducción de los eventos registrados en papel, verificación de señales y reconciliación del estado de los interruptores: 1,5 horas de trabajo de dos operadores, que es el WRT declarado

8. Costo de indisponibilidad por hora y por día

Es la métrica más característica del análisis de impacto. Se construye sumando, por cada hora de interrupción, los ingresos que dejan de percibirse, el costo del personal improductivo o en horas extra, las penalizaciones contractuales que se activan y el costo de las medidas alternas. Cuando la dirección pregunta qué se gana con la inversión en continuidad, esta es la cifra que responde.

Componente del costo	Costo por hora	Costo por día	Supuesto declarado y su origen
Ingresos que dejan de percibirse	USD 38 000	USD 912 000	Energía no suministrada durante la indisponibilidad del telecontrol, estimada sobre la demanda media de la zona atendida por las doce subestaciones (derivación de la ficha de datos del cliente: 190 MW de demanda media × USD 200 por MWh, bloque «Economía»)
Personal improductivo u horas extra	USD 9 500	USD 228 000	Doce operadores de campo, dos coordinadores y las cuadrillas de apoyo en horario extraordinario
Penalizaciones contractuales activadas	USD 4 500	USD 108 000	Compensaciones a clientes industriales con contrato de calidad de suministro (dato de la ficha, bloque «Operación por proceso»: USD 4 500 por hora, entre 2 000 y 9 000)
Costo del procedimiento alterno	USD 7 000	USD 168 000	Movilización de flota, viáticos, alquiler de equipo de medición portátil y consumo de radio
Otros costos directos	USD 3 000	USD 72 000	Soporte de emergencia del fabricante del sistema SCADA y horas de consultoría
Total	**USD 62 000**	**USD 1 488 000**	Escenario de temporada de lluvias; el escenario promedio anual rinde USD 38 750 por hora

Costo al alcanzar el MTPD de cuatro horas: USD 248 000. Esta cifra es la que sostiene la urgencia de los controles 12 y 13 en E.07 y la que el informe ejecutivo lleva a la dirección.

9. Valoración económica que el BIA entrega

El valor del activo es el valor económico total del proceso analizado e incluye el costo de reposición, el valor de la información que contiene y el flujo que genera. El factor de exposición es la proporción de ese valor que se pierde cuando el evento adverso ocurre, expresada entre cero y uno. La pérdida esperada por evento único es el producto de ambos.

Variable	Valor	Cómo se estimó y con qué fuente
AV — valor del activo o del proceso	USD 9 000 000	Valor anual atribuible al proceso de control de red: margen de la energía distribuida por las doce subestaciones principales más el valor de reposición de la plataforma SCADA (derivación de la ficha: USD 6,0 M de margen más USD 3,0 M de reposición, bloque «Economía»)
EF — factor de exposición (entre 0 y 1)	0,55	Proporción del valor del proceso que se pierde en el evento de referencia —cifrado o manipulación del entorno SCADA con indisponibilidad de 24 horas—, estimada con el criterio del dueño del proceso y el costo por día de la sección 8
SLE — pérdida esperada por evento único (SLE = AV × EF)	USD 4 950 000	9 000 000 × 0,55. El BIA entrega este valor; la frecuencia (ARO) y la pérdida anual esperada (ALE) se calculan en E.05, tabla D.6

Proceso con los datos personales que cuantifica la ficha. Cuando el proceso trata los titulares que la ficha de datos del cliente cuenta en el bloque «Economía», se calcula además el SLE de exposición de datos, también si el proceso resulta importante:

Variable	Valor	Fuente
Titulares de datos personales que trata el proceso	P-01 no trata datos de clientes; P-04 y P-05 tratan los 420 000 clientes	Ficha de datos del cliente, bloque «Economía»
Costo de notificar a un titular (USD)	0,25	Ficha de datos del cliente, bloque «Economía»
Otros costos por titular que la ficha cuantifica (USD)	Ninguno	Ficha de datos del cliente
AV de exposición = titulares × (costo de notificar + otros costos por titular)	USD 105 000	420 000 × 0,25
EF = proporción de titulares expuestos en el escenario (entre 0 y 1)	1,0	Escenario: exposición de toda la base
SLE de exposición = AV × EF	USD 105 000	SLE-05 (P-04) y SLE-06 (P-05) en E.03, tabla B.2

Escenarios del proceso. Un mismo proceso admite una pérdida por evento único por escenario (cifrado o indisponibilidad, exposición de datos, fraude, sabotaje de la operación). Cada escenario lleva su identificador SLE-nn, que la tabla B.2 de E.03 consolida y la matriz de riesgos de E.05 cita:

SLE-nn	Escenario	AV (USD)	EF	SLE = AV × EF (USD)
SLE-01	P-01: cifrado o manipulación del entorno SCADA con indisponibilidad de 24 horas	9 000 000	0,55	4 950 000
SLE-02	P-03: indisponibilidad por cifrado de la plataforma OMS	2 600 000	0,50	1 300 000
SLE-03	P-04: indisponibilidad del sistema comercial	3 100 000	0,45	1 395 000
SLE-04	P-02: indisponibilidad de la cabecera AMI	1 200 000	0,40	480 000
SLE-05	P-04: exposición de los datos personales de los clientes	105 000	1,0	105 000
SLE-06	P-05: exposición de los datos personales de los clientes	105 000	1,0	105 000

Frontera del análisis. Hasta aquí llega el BIA. La tasa anualizada de ocurrencia (ARO) y la pérdida anual esperada (ALE = SLE × ARO) pertenecen a la evaluación cuantitativa de riesgos, tal como la describe NIST SP 800-30 Rev. 1, porque ambas requieren estimar la probabilidad de la amenaza, y la probabilidad queda fuera del alcance del BIA. El BIA responde qué pasa si ocurre; el análisis de riesgos responde con qué frecuencia ocurrirá.

10. Método de valoración empleado

Método	Empleado	Justificación de la elección
Cuantitativo — valores monetarios	Sí	El proceso tiene costos por hora estimables con la demanda atendida y las compensaciones contractuales; la dirección decide inversiones y necesita cifras comparables con el costo de los controles
Cualitativo — escalas verbales alto, medio, bajo	Parcial	Se usa en las categorías reputacional y de seguridad de las personas, donde no hay base monetaria defendible; la matriz de BIA_P03 las califica en la escala 1–5
Semicuantitativo — valores numéricos sobre categorías cualitativas	Sí	La priorización de BIA_P05 convierte las cinco categorías en una escala 1–5 ponderada, lo que permite ordenar procesos con dimensiones no monetarias

El método semicuantitativo conserva la naturaleza ordinal de su origen: sus números ordenan y ponderan, y no admiten aritmética como si fueran dinero.

El método se declara aquí, en la ficha de cada proceso; BIA_P06 registra solo los supuestos y límites del método, y la sección 3 de BIA_P07 lo resume.

11. Validación

Rol	Nombre y cargo	Fecha	Firma
Analista que levanta la ficha	Diego Salguero Martínez, analista de riesgos	8 de octubre de 2026	(firma)
Dueño del proceso que valida	Ing. René Alfaro, Gerente de Operaciones de Red	8 de octubre de 2026	(firma)
Aprobación de la dirección	Ing. Óscar Mauricio Handal, Gerente General	12 de octubre de 2026	(firma)

12. Glosario de los campos de esta plantilla

Término	Definición
MTPD / MTD	Período máximo tolerable de interrupción: tiempo tras el cual el daño ya no puede revertirse. Lo fija el negocio.
RTO	Objetivo de tiempo de recuperación: plazo máximo para restaurar el proceso y sus sistemas de soporte.
WRT	Tiempo de recuperación del trabajo: plazo adicional para reconstruir los datos del período caído y validar su integridad.
RPO	Objetivo de punto de recuperación: cantidad máxima de datos que se acepta perder, medida en tiempo.
MBCO	Objetivo mínimo de continuidad del negocio: nivel reducido de servicio sostenido durante la contingencia.
AV, EF, SLE	Valor del activo, factor de exposición y pérdida esperada por evento único, con SLE = AV × EF.

Ficha resumida del otro proceso crítico y valoración de los procesos importantes con SLE

P-03 es el otro proceso crítico: su ficha completa se levantó con el mismo método y la validó su dueño; el detalle de impacto por corte de tiempo vive en BIA_P03 y sus dependencias en BIA_P04. P-04 y P-02 resultaron importantes en BIA_P05 (2,46) y conservan las secciones 3, 8 y 9 de la ficha: P-04 porque trata los datos personales de los 420 000 clientes que cuantifica la ficha (SLE-05), y los dos porque E.05 cuantifica con su SLE los riesgos R-07 y R-04. Sus MTPD, RTO, WRT, RPO y MBCO son los que declara el negocio y los que lista BIA_P05; la regla única de fichas no les exige matriz de BIA_P03 ni mapa de BIA_P04.

Variable	P-03 · Sistema de Gestión de Interrupciones (OMS), crítico	P-04 · Sistema Comercial y de Facturación, importante	P-02 · Gestión de Medición Inteligente (AMI), importante
Dueño del proceso	Ing. René Alfaro, Gerente de Operaciones de Red	Lic. Marta Rodríguez, Gerente Comercial	Ing. Sonia Portillo, Gerente Técnica
MTPD / MTD	8 horas	72 horas	48 horas
RTO	4 horas	24 horas	24 horas
WRT	3 horas	24 horas	12 horas
Comprobación RTO + WRT ≤ MTPD	4 + 3 = 7 ≤ 8	24 + 24 = 48 ≤ 72	24 + 12 = 36 ≤ 48
RPO	1 hora	4 horas	6 horas
MBCO declarado	Despacho de cuadrillas con planillas impresas y avisos al cliente por el centro de contacto, con corte de reporte cada dos horas	Facturación del ciclo con lectura estimada del período anterior para el 100 % de los clientes regulados, sin gestión de cobro en línea	Lectura manual del 15 % de clientes de mayor consumo y estimación para el resto

Variable	P-03 · Sistema de Gestión de Interrupciones (OMS), crítico	P-04 · Sistema Comercial y de Facturación, importante	P-02 · Gestión de Medición Inteligente (AMI), importante
Procedimiento alterno y duración máxima sostenible	Planillas impresas y radio; 24 horas con dos relevos	Estimación de consumo y emisión diferida; 7 días antes de afectar el flujo de caja	Lectura manual programada; 15 días antes de comprometer el ciclo de facturación
Costo por hora / por día	USD 18 500 / USD 444 000	USD 7 400 / USD 177 600	USD 2 900 / USD 69 600
Costo al alcanzar el MTPD	USD 148 000	USD 532 800	USD 139 200
AV · EF · SLE	USD 2 600 000 · 0,50 · USD 1 300 000	USD 3 100 000 · 0,45 · USD 1 395 000	USD 1 200 000 · 0,40 · USD 480 000
Período pico usado en la valoración	Temporada de lluvias, factor 2,8 × en volumen de avisos	Cierre de ciclo mensual, factor 1,9 ×	Cierre de ciclo diario y facturación mensual, factor 1,5 ×
Validación	Ing. René Alfaro, 12 de octubre de 2026	Lic. Marta Rodríguez, 12 de octubre de 2026	Ing. Sonia Portillo, 12 de octubre de 2026

ESEN

CIBERSEGURIDAD

Matriz de impacto por categoría y escala de tiempo

Del umbral de tolerancia se deriva el MTPD

Ejemplo resuelto de cátedra · Nexo Crítico Consultores · Energía Nacional S.A. de C.V. (ENSA)

Análisis de Impacto en el Negocio · Plantilla 03 de 07

ISO 22301:2019 · ISO/TS 22317:2021 · NIST SP 800-34 Rev. 1

Docente: Ing. Héctor Cuchilla

ESEN – CIBERSEGURIDAD – CICLO 03 – 2026

Tabla de contenidos

1. Identificación del trabajo..... 3
2. Cómo se llena..... 3
3. Escala de valoración declarada..... 3
4. Matriz de impacto..... 4
5. Umbral de tolerancia y derivación del MTPD..... 5
6. Punto de inflexión de la curva..... 5
7. Glosario de los campos de esta plantilla..... 6
Nivel financiero por corte con la escala proporcional..... 6
Matriz resumida del otro proceso crítico..... 6

Ejemplo resuelto de cátedra · anexo 3 de 7. La matriz corresponde al proceso P-01 (SCADA/OT); al final se resume la matriz del otro proceso crítico, P-03 (OMS).

1. Identificación del trabajo

Esta plantilla se llena por equipo y sobre la empresa que el equipo tiene asignada en el catálogo del Proyecto Final. El caso resuelto que la Guía del Estudiante desarrolla usa la Red Hospitalaria Metropolitana; cada equipo aplica el mismo método a su propia empresa.

Campo	Contenido
Empresa del catálogo del Proyecto Final	Energía Nacional S.A. de C.V. (ENSA), perfil n.º 4
Sector y tamaño declarados en el perfil	Energía y servicios públicos · mediana, 550 empleados
Equipo (número y nombre)	Equipo 04 · Nexo Crítico Consultores
Integrantes	Seis integrantes con los cinco roles cubiertos
Analista responsable de esta plantilla	Diego Salguero Martínez, analista de riesgos
Fecha de elaboración	12 de octubre de 2026
Versión del documento	v1.0

2. Cómo se llena

El impacto no es constante: crece con la duración de la interrupción, y rara vez lo hace de forma lineal. Cada una de las cinco categorías se evalúa por separado en cinco cortes de tiempo, y la curva resultante revela el punto de inflexión, que es el momento en que el daño se dispara. El corte en que la curva cruza el umbral de tolerancia determina el MTPD del proceso, y así el MTPD deja de ser una opinión y pasa a ser el resultado de una medición.

Proceso evaluado: _____ **Escenario temporal:** _____

3. Escala de valoración declarada

La categoría financiera se califica con una escala proporcional a las ventas o ingresos anuales que trae la ficha de datos del cliente (bloque «Economía»; en las entidades públicas y sin fines de lucro, el presupuesto operativo anual). Los porcentajes son fijos para todos los equipos: el equipo anota el monto de la ficha y calcula los límites en dólares de su organización. Las otras cuatro categorías se califican con el criterio verbal que el equipo declara para cada nivel.

Ventas o ingresos anuales de la ficha (USD): 360 000 000, ingresos anuales por venta de energía y cargos de distribución (bloque «Economía» de la ficha de datos del cliente de ENSA).

Nivel	Etiqueta	Pérdida financiera del corte, en % de las ventas anuales	Límites en USD para la organización	Criterio verbal de las otras cuatro categorías	Valor semicuantitativo
1	Bajo	Menos de 0,01 %	Menos de 36 000	Sin efecto sobre clientes ni sobre el regulador	1
2	Moderado	De 0,01 % a menos de 0,05 %	De 36 000 a menos de 180 000	Molestia acotada a clientes de una zona	2
3	Alto	De 0,05 % a menos de 0,25 %	De 180 000 a menos de 900 000	Reclamo del regulador o cobertura local negativa	3
4	Grave	De 0,25 % a 1 %	De 900 000 a 3 600 000	Incumplimiento regulatorio con sanción probable o riesgo a la integridad física del personal	4
5	Crítico	Más de 1 %	Más de 3 600 000	Apagón extendido con daño a terceros, riesgo de vida o sanción regulatoria grave	5

Ejemplo de cálculo: con ventas anuales de USD 360 millones, los límites son USD 36 000 (0,01 %), 180 000 (0,05 %), 900 000 (0,25 %) y 3 600 000 (1 %); una pérdida de USD 1 488 000 en el corte de 24 horas equivale al 0,41 % y se califica en el nivel 4.

Cuando el criterio monetario y el criterio verbal arrojan niveles distintos para un mismo corte, se registra el mayor de los dos.

Regla de redondeo: el porcentaje de cada corte se calcula con dos decimales sobre el monto de la ficha y se ubica en la tabla tal como está escrita; el puntaje de criticidad de BIA_P05 se redondea a dos decimales, la mitad hacia arriba.

La escala es la proporcional a las ventas que fija la Guía BIA (paso 4); se aprueba con la Gerencia General el 12 de octubre de 2026 y se usa igual en los dos procesos críticos y en la precalificación de los ocho restantes, de modo que los puntajes sean comparables entre sí y con la ponderación de BIA_P05.

4. Matriz de impacto

Categoría de impacto	4 horas	24 horas	72 horas	1 semana	1 mes
Financiero — ingresos perdidos, multas, remediación, compensaciones	3 (USD 248 000; 0,07 %)	4 (USD 1 488 000; 0,41 %)	5 (USD 4 464 000; 1,24 %)	5	5
Operativo — producción detenida, servicios dependientes, procesos alternos	4 (operación manual al límite de su relevo)	5 (procedimiento alterno agotado a las 12 h)	5	5	5
Legal y regulatorio — incumplimiento, sanciones, pérdida de licencia	3 (reporte obligatorio de interrupción)	4 (incumplimiento de indicadores de continuidad)	5 (proceso sancionatorio)	5	5
Reputacional — confianza de clientes, cobertura negativa, marca	3 (cobertura local)	4 (cobertura nacional)	5	5	5

Categoría de impacto	4 horas	24 horas	72 horas	1 semana	1 mes
Seguridad de las personas — vida e integridad física	4 (maniobra manual sin telemetría en subestación energizada)	5 (riesgo a cuadrillas y a clientes con equipo de soporte vital)	5	5	5
Impacto consolidado del corte	**4 — Grave**	**5 — Crítico**	**5 — Crítico**	**5 — Crítico**	**5 — Crítico**

En un hospital, en una planta industrial o en un servicio público esencial, la categoría de seguridad de las personas manda sobre las otras cuatro y decide por sí sola el orden de recuperación.

5. Umbral de tolerancia y derivación del MTPD

El umbral de tolerancia es el nivel de daño que la organización declara inaceptable. Se acuerda con la dirección antes de mirar la matriz, para que la medición no se ajuste a la conclusión deseada.

Campo	Contenido
Umbral de tolerancia declarado (nivel o monto)	Nivel 4 (Grave) en cualquier categoría; en la financiera, una pérdida del corte de USD 900 000 o más (0,25 % de las ventas de la ficha)
Quién lo aprueba (nombre y cargo)	Ing. Óscar Mauricio Handal, Gerente General
Fecha de aprobación	12 de octubre de 2026
Primer corte de tiempo en que alguna categoría cruza el umbral	4 horas
Categoría que produce el cruce	Seguridad de las personas y operativo, ambas en nivel 4; el financiero queda en el nivel 3 (USD 248 000, 0,07 % de las ventas)
MTPD derivado del cruce	**4 horas**
MTPD declarado en la ficha del proceso	4 horas
Coincidencia entre ambos (Sí / No) y explicación de la diferencia	Sí. El dueño del proceso declaró cuatro horas por el agotamiento de la maniobra manual y la matriz lo confirma por la vía del impacto: las dos derivaciones coinciden sin ajuste

El impacto consolidado del corte es el mayor de las cinco categorías; el umbral expresa intolerancia y no promedio.

6. Punto de inflexión de la curva

Describir en qué corte el impacto deja de crecer de forma gradual y se dispara, y qué mecanismo lo explica: la pérdida de la licencia, el vencimiento de un plazo contractual, la fuga de clientes, el riesgo para la vida.

El impacto crece de forma no lineal entre las cuatro y las veinticuatro horas: el procedimiento alterno sostiene la operación con un solo relevo hasta las doce horas, y a partir de ahí las categorías operativa y de seguridad de las personas saltan de 4 a 5 al mismo tiempo. El punto de inflexión es, por tanto, el corte de 24 horas, y el MTPD de cuatro horas deja un margen deliberado antes de él. La consecuencia de diseño es que la recuperación del sistema SCADA no admite depender de un respaldo que exija más de dos horas de restauración: por eso el control 11 (recuperación de datos) entra entre los seis desarrollados a profundidad en E.07.

7. Glosario de los campos de esta plantilla

Término	Definición
Categoría de impacto	Dimensión en que se mide el daño de la interrupción. El análisis usa cinco: financiero, operativo, legal y regulatorio, reputacional, y seguridad de las personas.
Corte de tiempo	Duración de interrupción en que se evalúa el impacto. La asignación usa cinco: 4 horas, 24 horas, 72 horas, 1 semana y 1 mes.
Umbral de tolerancia	Nivel de daño que la organización declara inaceptable y que la dirección aprueba antes de la valoración.
Punto de inflexión	Corte de tiempo a partir del cual el impacto crece de forma abrupta.

Nivel financiero por corte con la escala proporcional

Proceso	Costo por hora (USD)	4 h	24 h	72 h	1 semana	1 mes
P-01 SCADA/OT	62 000	3 (248 000)	4 (1 488 000)	5 (4 464 000)	5 (10 416 000)	5 (44 640 000)
P-03 OMS	18 500	2 (74 000)	3 (444 000)	4 (1 332 000)	4 (3 108 000)	5 (13 320 000)

El costo por hora se toma constante, con la cifra de temporada de lluvias de la ficha (una semana = 168 horas; un mes = 720 horas). En cada corte el nivel financiero es menor o igual que el impacto consolidado, que toma la mayor de las cinco categorías; por eso el MTPD derivado de los dos procesos críticos se mantiene con la escala proporcional. El nivel financiero de los procesos importantes a las 24 horas entra en la precalificación de BIA_P05.

Matriz resumida del otro proceso crítico

Proceso	Impacto a 4 h	24 h	72 h	1 semana	1 mes	Corte en que cruza el umbral	MTPD derivado
P-03 · OMS	3	4	5	5	5	8 horas (interpolado entre los cortes de 4 y 24 h, con el agotamiento del despacho manual)	8 horas

En P-03 el MTPD derivado de la matriz coincide con el declarado en la ficha de BIA_P02. P-04 y P-02 resultaron importantes en la precalificación de BIA_P05 y, por la regla única de fichas, no llevan matriz: sus consecuencias a las

24 horas son moderadas y alcanzan el nivel crítico en días. La distancia entre los procesos de tecnología de operación, que llegan al nivel crítico en horas, y los procesos comerciales es la enseñanza central del análisis, y ordena la prioridad de los controles y del roadmap.

ESEN

CIBERSEGURIDAD

Mapa de dependencias y recursos mínimos

Seis clases de dependencia, recursos del MBCO y puntos únicos de falla

Ejemplo resuelto de cátedra · Nexo Crítico Consultores · Energía Nacional S.A. de C.V. (ENSA)

Análisis de Impacto en el Negocio · Plantilla 04 de 07

ISO 22301:2019 · ISO/TS 22317:2021 · NIST SP 800-34 Rev. 1

Docente: Ing. Héctor Cuchilla

ESEN – CIBERSEGURIDAD – CICLO 03 – 2026

Tabla de contenidos

1. Identificación del trabajo..... 3
2. Cómo se llena..... 3
3. Las seis clases de dependencia..... 3
4. Recursos mínimos de recuperación consolidados..... 5
5. Interdependencias entre procesos..... 5
6. Secuencia de recuperación propuesta..... 6
7. Glosario de los campos de esta plantilla..... 6

Ejemplo resuelto de cátedra · anexo 4 de 7. Las dependencias corresponden al proceso P-01 (SCADA/OT) y, en las secciones 5 y 6, a la cadena completa de los dos procesos críticos y de los procesos importantes que dependen de ellos.

1. Identificación del trabajo

Esta plantilla se llena por equipo y sobre la empresa que el equipo tiene asignada en el catálogo del Proyecto Final. El caso resuelto que la Guía del Estudiante desarrolla usa la Red Hospitalaria Metropolitana; cada equipo aplica el mismo método a su propia empresa.

Campo	Contenido
Empresa del catálogo del Proyecto Final	Energía Nacional S.A. de C.V. (ENSA), perfil n.º 4
Sector y tamaño declarados en el perfil	Energía y servicios públicos · mediana, 550 empleados
Equipo (número y nombre)	Equipo 04 · Nexo Crítico Consultores
Integrantes	Seis integrantes con los cinco roles cubiertos
Analista responsable de esta plantilla	Diego Salguero Martínez, analista de riesgos
Fecha de elaboración	12 de octubre de 2026
Versión del documento	v1.0

2. Cómo se llena

Ningún proceso opera solo. El mapa de dependencias es la parte del análisis que más hallazgos produce, porque expone compromisos que nadie había escrito. De cada dependencia se extraen dos datos: el recurso mínimo que exige para operar en el nivel del MBCO, que es siempre menor que el requerimiento de la operación normal, y si constituye un punto único de falla, es decir una dependencia sin alternativa cuya caída detiene el proceso por completo.

Proceso analizado: _____

3. Las seis clases de dependencia

Clase de dependencia	Dependencia concreta	Recurso mínimo para operar en el MBCO	SPOF (Sí/No)	Alternativa disponible	Observaciones
Personas y competencias críticas	Ingeniero especialista en la plataforma SCADA Siemens, único con credenciales de administración y conocimiento de la configuración	Un ingeniero con acceso administrativo y dos operadores por turno	Sí	Soporte remoto del fabricante con tiempo de respuesta de 8 horas	SPOF-01: la competencia no está documentada ni replicada; alimenta el riesgo R-14 de E.05

Clase de dependencia	Dependencia concreta	Recurso mínimo para operar en el MBCO	SPOF (Sí/No)	Alternativa disponible	Observaciones
Personas y competencias críticas	Operadores de campo habilitados para maniobra local en subestación	Doce operadores por turno con habilitación vigente	No	Personal de cuadrillas de mantenimiento con habilitación equivalente	La habilitación se vence anualmente; su control es administrativo
Aplicaciones y sistemas	Servidores de adquisición y de aplicación del SCADA, estaciones HMI del centro de control	Un servidor de adquisición y dos HMI operativas	Sí	Centro de control alterno declarado en el plan, sin equipamiento instalado	SPOF-02: no hay redundancia geográfica del centro de control
Aplicaciones y sistemas	Servicio de directorio corporativo para la autenticación de los operadores	Autenticación local de emergencia en las HMI	Sí	Cuentas locales de emergencia en sobre sellado	SPOF-03: la dependencia del directorio de TI es la vía por la que un incidente de TI alcanza a la operación
Datos y registros vitales (ubicación, formato, respaldo)	Base de datos de tiempo real y archivos de configuración del SCADA; ubicados en el centro de datos corporativo, con respaldo en cinta semanal	Respaldo restaurable con antigüedad máxima de 15 minutos (RPO)	Sí	Ninguna: el respaldo semanal no cumple el RPO declarado	Brecha B-01: el respaldo vigente no sostiene el RPO ni el RTO; es el origen de la prioridad del control 11
Datos y registros vitales	Registros de eventos y maniobras (bitácora operativa)	Formulario impreso F-OP-12 durante la contingencia	No	Registro manual y reintroducción posterior	El esfuerzo de reintroducción es el WRT de 1,5 horas
Proveedores y terceros (servicio y nivel comprometido)	Fabricante del sistema SCADA: soporte correctivo y mantenimiento remoto	Canal de soporte disponible con respuesta en 8 horas	Sí	Ninguna: la plataforma es propietaria	SPOF-04: el acceso remoto del proveedor no usa autenticación multifactor; origen del riesgo R-02 y de la salvaguarda 6.5
Proveedores y terceros	Operador de telecomunicaciones de los enlaces con subestaciones	Radio troncalizado propio como medio alterno	No	Radio troncalizado con batería de respaldo de 12 horas	El medio alterno es el que sostiene el MBCO
Instalaciones	Centro de control de red en el centro de operaciones de San Salvador	Sala de control con energía respaldada y radio operativo	Sí	Puesto de mando móvil, no equipado a la fecha	SPOF-02 (misma raíz que la aplicación)
Equipamiento y servicios básicos (energía, clima, red, agua)	Energía respaldada del centro de datos y del centro de control: UPS y planta de emergencia	UPS con 30 minutos y planta con 24 horas de combustible	No	Contrato de suministro de combustible con entrega en 6 horas	Prueba de planta trimestral registrada
Equipamiento y servicios básicos	Climatización del centro de datos corporativo	Una unidad de las dos instaladas	No	Redundancia N+1 instalada	Sin observación

Una fila por dependencia, con al menos una por clase: las filas pre-formateadas son orientación de volumen y no un cupo.

Una persona que es la única que conoce el procedimiento, un proveedor sin sustituto, un enlace sin respaldo o un servidor sin réplica son puntos únicos de falla, y suelen ser el hallazgo más barato de corregir y el más caro de ignorar.

4. Recursos mínimos de recuperación consolidados

Cuantificar lo que la recuperación exige para sostener el nivel del MBCO, no la operación normal. Esta tabla es la que dimensiona el sitio alterno y el presupuesto de contingencia.

Recurso	Requerimiento en operación normal	Requerimiento mínimo en MBCO	Dónde se obtiene durante la contingencia
Personas (número y perfil)	6 operadores de centro de control por turno y 1 ingeniero SCADA	12 operadores de campo, 2 coordinadores y 1 ingeniero SCADA	Turnos de la Gerencia de Operaciones de Red y llamado a personal de guardia
Estaciones de trabajo y dispositivos	8 estaciones HMI y 4 estaciones de ingeniería	2 estaciones HMI y 12 radios troncalizados	Centro de control; bodega técnica para radios de repuesto
Capacidad de red y conectividad	Enlaces dedicados con las doce subestaciones principales	Radio troncalizado con cobertura de las doce subestaciones	Red propia de radio, con repetidores en tres cerros
Instalación física	Centro de control de red	Sala de reuniones de la Gerencia de Operaciones habilitada como puesto de mando	Centro de operaciones de San Salvador
Aplicaciones y datos disponibles	SCADA completo con histórico y GIS	Diagramas unifilares impresos y última copia de la configuración	Carpeta de contingencia del centro de control, actualizada mensualmente
Insumos y equipamiento especializado	Equipo de medición fija en subestación	Equipo de medición portátil y formularios F-OP-12 impresos	Bodega técnica y flota de la Gerencia Técnica

5. Interdependencias entre procesos

Los procesos también dependen unos de otros, y esa red condiciona el orden de recuperación. Si la facturación necesita los datos de la admisión, recuperar la facturación primero no produce ningún servicio. Un proceso de criticidad media que alimenta a tres procesos críticos hereda la urgencia de aquellos a los que sostiene.

Procesos que alimentan a este	Qué le entregan	Procesos que se alimentan de este	Qué reciben	Consecuencia sobre el orden de recuperación
P-09 Gestión de TI corporativa	Identidad y autenticación de los operadores, resolución de nombres y servicios de red compartidos	P-03 OMS	Estado de interruptores y confirmación de maniobras	La identidad se recupera antes que el telecontrol, o se opera con las cuentas locales de emergencia
P-06 Gestión de campo y cuadrillas	Confirmación de maniobra local y estado real del equipo en sitio	P-02 AMI	Ventana de operación de la red para la lectura de medidores	El OMS depende del SCADA: su recuperación va inmediatamente después
Proveedor de telecomunicaciones (externo)	Enlaces con subestaciones	P-10 Contabilidad y reportes regulatorios	Datos de interrupciones para el reporte al regulador	El reporte regulatorio tolera días; va al final de la secuencia

6. Secuencia de recuperación propuesta

Orden	Proceso	Por qué va en esa posición	Depende de que antes se recupere
1	P-01 Operación de la Red de Control (SCADA/OT)	MTPD de 4 horas, el más corto del análisis, y afecta la seguridad de terceros	Energía respaldada, enlaces o radio, y autenticación de emergencia
2	P-03 Sistema de Gestión de Interrupciones (OMS)	MTPD de 8 horas; sin él la restauración del servicio se coordina a ciegas	P-01 y el servicio de GIS
3	P-09 Gestión de TI corporativa	Habilita identidad, correo y puesto de trabajo de los procesos comerciales	Centro de datos corporativo operativo
4	P-02 Gestión de Medición Inteligente (AMI)	Proceso importante; MTPD de 48 horas; alimenta la facturación del ciclo	P-01 restablecido para operar la red de medición
5	P-04 Sistema Comercial y de Facturación	Proceso importante; MTPD de 72 horas, el más largo de la secuencia	P-09 y P-02
6	P-06 Gestión de campo y cuadrillas con GIS	Proceso importante; opera con planillas impresas mientras tanto	P-09

La secuencia se deriva del MTPD y de las interdependencias entre procesos. El equipo la declara como propuesta del BIA: su aprobación formal corresponde al plan de continuidad, que queda fuera del alcance de este proyecto y entra al roadmap de E.10 como iniciativa del mediano plazo.

7. Glosario de los campos de esta plantilla

Término	Definición
Dependencia	Recurso externo al proceso sin el cual este no puede ejecutarse. El análisis levanta seis clases.
Recurso mínimo de recuperación	Cantidad de cada recurso necesaria para operar en el nivel del MBCO durante la contingencia.
SPOF — punto único de falla	Dependencia sin alternativa cuya indisponibilidad detiene el proceso por completo.
Interdependencia	Relación entre procesos por la que uno entrega a otro una entrada necesaria.

ESEN

CIBERSEGURIDAD

Matriz de criticidad y priorización

Un puntaje explícito y reproducible en lugar de una discusión

Ejemplo resuelto de cátedra · Nexo Crítico Consultores · Energía Nacional S.A. de C.V. (ENSA)

Análisis de Impacto en el Negocio · Plantilla 05 de 07

ISO 22301:2019 · ISO/TS 22317:2021 · NIST SP 800-34 Rev. 1

Docente: Ing. Héctor Cuchilla

ESEN – CIBERSEGURIDAD – CICLO 03 – 2026

Tabla de contenidos

1. Identificación del trabajo..... 3
2. Cómo se llena..... 3
3. Pesos acordados con la dirección..... 3
4. Matriz de criticidad..... 4
5. Reglas de clasificación declaradas..... 5
6. Lista priorizada de procesos..... 6
7. Enganche con los marcos del curso..... 6
8. Glosario de los campos de esta plantilla..... 7

Ejemplo resuelto de cátedra · anexo 5 de 7. Los diez procesos del censo de BIA_P01 se puntúan con los pesos acordados con la dirección y se ordenan en una lista única.

1. Identificación del trabajo

Esta plantilla se llena por equipo y sobre la empresa que el equipo tiene asignada en el catálogo del Proyecto Final. El caso resuelto que la Guía del Estudiante desarrolla usa la Red Hospitalaria Metropolitana; cada equipo aplica el mismo método a su propia empresa.

Campo	Contenido
Empresa del catálogo del Proyecto Final	Energía Nacional S.A. de C.V. (ENSA), perfil n.º 4
Sector y tamaño declarados en el perfil	Energía y servicios públicos · mediana, 550 empleados
Equipo (número y nombre)	Equipo 04 · Nexo Crítico Consultores
Integrantes	Seis integrantes con los cinco roles cubiertos
Analista responsable de esta plantilla	Mariela Cortez Aguilar, analista de riesgos
Fecha de elaboración	13 de octubre de 2026
Versión del documento	v1.0

2. Cómo se llena

La priorización se resuelve con un puntaje explícito. Cada proceso recibe una calificación en cada categoría de impacto, evaluada en el mismo corte para todos los procesos; cada categoría lleva un peso acordado con la dirección; y el puntaje de criticidad es la suma ponderada, ajustada por el número de procesos que dependen de él. Que el método sea explícito importa más que su sofisticación: hace la decisión auditable y permite que otro analista, con los mismos datos, llegue al mismo resultado.

Convención del proyecto: todos los procesos del censo se precalifican en el corte de 24 horas con las consecuencias que la ficha de datos del cliente trae para ese corte; los que resultan críticos llevan ficha BIA_P02, matriz BIA_P03 y mapa BIA_P04, y sus calificaciones de BIA_P03 sustituyen a las provisionales. El corte del MTPD más corto sesga el resultado contra los procesos que toleran horas y no días; el equipo que adopta otra regla —cada proceso en el corte de su propio MTPD— la justifica en la línea «Corte de tiempo». Puntaje final = suma ponderada × (1 + 0,10 × número de procesos dependientes), redondeado a dos decimales con la mitad hacia arriba: 4,35 con un dependiente da 4,35 × 1,10 = 4,785, que se registra como 4,79.

3. Pesos acordados con la dirección

Categoría de impacto	Peso asignado	Fundamento del peso	Aprobado por
Financiero	15 %	La pérdida de ingresos es recuperable con facturación diferida; no es la dimensión que gobierna las decisiones de continuidad de una distribuidora	Ing. Óscar Mauricio Handal, Gerente General

Categoría de impacto	Peso asignado	Fundamento del peso	Aprobado por
Operativo	25 %	La continuidad del suministro es el servicio que la empresa existe para prestar	Ing. Óscar Mauricio Handal
Legal y regulatorio	20 %	Las obligaciones de continuidad y calidad ante el ente regulador, y la LPDP sobre los datos de consumo, tienen consecuencia directa	Ing. Óscar Mauricio Handal
Reputacional	10 %	El daño de imagen acompaña a las otras categorías y rara vez decide por sí solo	Ing. Óscar Mauricio Handal
Seguridad de las personas	30 %	La indisponibilidad del telecontrol expone a cuadrillas y a clientes con equipo de soporte vital: es el peso mayor por decisión explícita de la dirección	Ing. Óscar Mauricio Handal
Suma de los pesos (debe totalizar 100 %)	**100 %**	Aprobados en la reunión del 13 de octubre de 2026	Acta de la Gerencia General

Corte de tiempo en que se evalúan las calificaciones (convención: 24 horas; otra regla, con su justificación): 24 horas, la convención del proyecto, para los diez procesos. **Ajuste por dependientes aplicado (suma ponderada × (1 + 0,10 × n), dos decimales):** fórmula de la guía, con n = número de procesos que dependen del evaluado y redondeo a dos decimales, la mitad hacia arriba.

4. Matriz de criticidad

Proceso	Fin.	Oper.	Legal	Reput.	Personas	Suma ponderada	Procesos dependientes	Puntaje final	Clase
P-01 Operación de la Red de Control (SCADA/OT)	4	5	5	5	5	4,85	3	6,31	Crítico
P-03 Sistema de Gestión de Interrupciones (OMS)	3	5	4	5	4	4,20	1	4,62	Crítico
P-09 Gestión de TI corporativa	2	3	3	2	1	2,15	3	2,80	Importante
P-06 Gestión de campo y cuadrillas con GIS	2	3	2	3	2	2,35	1	2,59	Importante
P-04 Sistema Comercial y de Facturación	2	3	2	3	1	2,05	2	2,46	Importante
P-02 Gestión de Medición Inteligente (AMI)	2	3	2	3	1	2,05	2	2,46	Importante
P-05 Atención al cliente y centro de contacto	1	2	2	4	1	1,75	1	1,93	Importante
P-10 Contabilidad y reportes regulatorios	2	1	3	2	1	1,65	0	1,65	Diferible
P-08 Nómina y administración de personal	2	1	3	2	1	1,65	0	1,65	Diferible

Proceso	Fin.	Oper.	Legal	Reput.	Personas	Suma ponderada	Procesos dependientes	Puntaje final	Clase
P-07 Compras y contratación de terceros	2	2	2	1	1	1,60	0	1,60	Diferible

Clase: crítico, importante o diferible, según los cortes de puntaje que el equipo declare en la sección 5.

La suma ponderada aplica los pesos de la sección 3 a las calificaciones del corte de 24 horas: las de BIA_P03 en los dos procesos críticos con matriz, P-01 y P-03, y las de la precalificación del equipo en los ocho restantes, hecha con las consecuencias que la ficha de datos del cliente trae para el corte de 24 horas. La calificación financiera sale de la escala proporcional de BIA_P03 (P-01: USD 1 488 000, 0,41 % de las ventas, nivel 4; P-03: 444 000, nivel 3) y, en la precalificación, del costo por hora de BIA_P02 por veinticuatro horas (P-04: 177 600, 0,049 %, nivel 2; P-02: 69 600, nivel 2). La categoría legal de P-04 y de P-02 a las 24 horas es 2: para ese corte la ficha describe en P-04 «facturas del ciclo retrasadas; cobro detenido» y en P-02 la pérdida parcial de las lecturas del cierre diario con el arranque de la lectura manual; la queja ante el regulador aparece en la semana en P-02 y la observación del regulador, en el mes en P-04. Con esas calificaciones, cada uno suma 0,30 + 0,75 + 0,40 + 0,30 + 0,30 = 2,05 y, con dos procesos dependientes, 2,05 × 1,20 = 2,46. El puntaje final aplica la fórmula de la guía, suma ponderada × (1 + 0,10 × número de procesos dependientes), redondeada a dos decimales con la mitad hacia arriba: P-03 da 4,20 × 1,10 = 4,62, y P-01, 4,85 × 1,30 = 6,305, que se registra como 6,31. A igual puntaje decide el mayor costo de indisponibilidad por hora (S-11): P-04, con USD 7 400 por hora, precede a P-02, con 2 900.

5. Reglas de clasificación declaradas

Clase	Rango de puntaje	Qué implica para la planificación de continuidad
Crítico	2,90 o más	Exige métricas de tiempo completas, procedimiento alterno probado, recurso mínimo de recuperación identificado y tratamiento prioritario en la matriz de riesgos
Importante	1,90 a 2,89	Exige métricas de tiempo y procedimiento alterno documentado; su tratamiento entra al roadmap con horizonte mediano
Diferible	Menor a 1,90	Se recupera después de los anteriores; basta con el respaldo de sus datos y un tiempo de recuperación declarado

Los umbrales se expresan en la escala de la fórmula de la guía, que multiplica la suma ponderada y no tiene tope. P-09, con 2,80, queda como importante y es el proceso más cercano al umbral de la clase crítica; el equipo lo vigila en el análisis de sensibilidad de BIA_P06. Con estos rangos, la clase crítica reúne a P-01 (6,31) y P-03 (4,62); la importante, a P-09 (2,80), P-06 (2,59), P-04 (2,46), P-02 (2,46) y P-05 (1,93); y la diferible, a P-10 y P-08 (1,65) y a P-07 (1,60). El resultado confirma como críticos dos de los cuatro procesos que el perfil del catálogo declara críticos. P-04 y P-02 quedan como importantes: a las 24 horas ninguna de sus calificaciones pasa de 3 y su impacto crece en días, con un MTPD de 72 horas en P-04 y de 48 horas en P-02. La diferencia con el perfil se registra en la sección A.3 de la versión 1.1 de E.02; los dos procesos siguen en el alcance y conservan su valoración económica en las secciones 3, 8 y 9 de BIA_P02.

6. Lista priorizada de procesos

El resultado del análisis de impacto es una lista única y ordenada. Esta tabla es una de las dos salidas propias del BIA; la otra es el costo de la interrupción por unidad de tiempo.

Orden	Proceso	Puntaje final	Clase	MTPD	RTO	WRT	RPO
1	P-01 Operación de la Red de Control (SCADA/OT)	6,31	Crítico	4 h	2 h	1,5 h	15 min
2	P-03 Sistema de Gestión de Interrupciones (OMS)	4,62	Crítico	8 h	4 h	3 h	1 h
3	P-09 Gestión de TI corporativa	2,80	Importante	24 h	8 h	4 h	4 h
4	P-06 Gestión de campo y cuadrillas con GIS	2,59	Importante	48 h	24 h	8 h	8 h
5	P-04 Sistema Comercial y de Facturación	2,46	Importante	72 h	24 h	24 h	4 h
6	P-02 Gestión de Medición Inteligente (AMI)	2,46	Importante	48 h	24 h	12 h	6 h
7	P-05 Atención al cliente y centro de contacto	1,93	Importante	24 h	8 h	4 h	8 h
8	P-10 Contabilidad y reportes regulatorios	1,65	Diferible	1 semana	72 h	24 h	24 h
9	P-08 Nómina y administración de personal	1,65	Diferible	1 semana	72 h	24 h	24 h
10	P-07 Compras y contratación de terceros	1,60	Diferible	2 semanas	1 semana	24 h	24 h

En los diez procesos se cumple RTO + WRT ≤ MTPD. El empate entre P-04 y P-02, con 2,46, se resolvió por el mayor costo de indisponibilidad por hora y quedó registrado como supuesto S-11 en BIA_P06.

7. Enganche con los marcos del curso

Los resultados de esta matriz alimentan la función de identificar de NIST CSF 2.0 con la priorización de activos y procesos, la función de recuperar con los objetivos de tiempo, y la función de gobernar con el apetito de riesgo declarado por la dirección. En los controles CIS v8.1, el inventario de dependencias sostiene los controles de inventario de activos empresariales y de software, y la protección de los datos y registros vitales sostiene el control de recuperación de datos.

Resultado del BIA	Función de NIST CSF 2.0 que alimenta	Control CIS v8.1 que sostiene
Lista priorizada de procesos y activos		
Objetivos de tiempo (MTPD, RTO, WRT, RPO)		
Inventario de dependencias		

Resultado del BIA	Función de NIST CSF 2.0 que alimenta	Control CIS v8.1 que sostiene
Datos y registros vitales		

Dentro del Proyecto Final, esta priorización sustenta el orden de implantación de las salvaguardas del IG asignado dentro del roadmap de E.10.

8. Glosario de los campos de esta plantilla

Término	Definición
Puntaje de criticidad	Suma ponderada de las calificaciones de impacto de un proceso, ajustada por el número de procesos que dependen de él.
Peso de la categoría	Proporción con que cada categoría de impacto contribuye al puntaje, acordada con la dirección.
Grupo de implementación (IG)	Nivel de adopción de las salvaguardas CIS v8.1 que corresponde al perfil de riesgo de la organización.

ESEN

CIBERSEGURIDAD

Registro de supuestos, puntos únicos de falla y brechas

Donde vive la evidencia del rigor del análisis

Ejemplo resuelto de cátedra · Nexo Crítico Consultores · Energía Nacional S.A. de C.V. (ENSA)

Análisis de Impacto en el Negocio · Plantilla 06 de 07

ISO 22301:2019 · ISO/TS 22317:2021 · NIST SP 800-34 Rev. 1

Docente: Ing. Héctor Cuchilla

ESEN – CIBERSEGURIDAD – CICLO 03 – 2026

Tabla de contenidos

1. Identificación del trabajo..... 3
2. Cómo se llena..... 3
3. Registro de supuestos y análisis de sensibilidad..... 3
4. Puntos únicos de falla identificados..... 5
5. Brechas detectadas por el análisis..... 6
6. Valoración con rangos: la alternativa FAIR..... 6
7. Glosario de los campos de esta plantilla..... 7

Ejemplo resuelto de cátedra · anexo 6 de 7. Aquí vive la evidencia del rigor del análisis: todo dato que el perfil del catálogo no declara aparece con su identificador, su origen y su rango.

1. Identificación del trabajo

Esta plantilla se llena por equipo y sobre la empresa que el equipo tiene asignada en el catálogo del Proyecto Final. El caso resuelto que la Guía del Estudiante desarrolla usa la Red Hospitalaria Metropolitana; cada equipo aplica el mismo método a su propia empresa.

Campo	Contenido
Empresa del catálogo del Proyecto Final	Energía Nacional S.A. de C.V. (ENSA), perfil n.º 4
Sector y tamaño declarados en el perfil	Energía y servicios públicos · mediana, 550 empleados
Equipo (número y nombre)	Equipo 04 · Nexo Crítico Consultores
Integrantes	Seis integrantes con los cinco roles cubiertos
Analista responsable de esta plantilla	Iván Cardoza Linares, oficial de calidad, con los dos analistas de riesgos
Fecha de elaboración	14 de octubre de 2026
Versión del documento	v1.0

2. Cómo se llena

Todo análisis de impacto descansa en estimaciones, y una conclusión que solo se sostiene con la estimación más optimista no es una conclusión. Cada supuesto se declara con su origen y su fecha, se varía en tres escenarios y se observa cuánto se mueve el resultado. Si la recomendación se mantiene en los tres escenarios, es robusta y se presenta como tal; si cambia de signo al variar un solo supuesto, la recomendación depende de ese supuesto y el informe ejecutivo debe decirlo con esas palabras.

3. Registro de supuestos y análisis de sensibilidad

ID (S-nn, global)	Supuesto declarado	Valor usado	Origen y fecha de la fuente	Mínimo	Esperado	Máximo	Efecto sobre la conclusión
S-06	Sin uso: las doce subestaciones principales con equipo de control conectado al SCADA son un dato de la ficha, y un dato de la ficha nunca se sustituye por un supuesto; el identificador se conserva para no alterar la numeración global	Dato de la ficha: 12	Ficha de datos del cliente, bloque «Economía»	8	12	20	Dimensiona el MBCO y el costo del procedimiento alterno; no altera el MTPD

ID (S-nn, global)	Supuesto declarado	Valor usado	Origen y fecha de la fuente	Mínimo	Esperado	Máximo	Efecto sobre la conclusión
S-07	Entrevistas, participantes y fechas del levantamiento	Cinco dueños de proceso	Supuesto del ejercicio; el perfil no describe personas · 6 oct 2026	—	—	—	Sin efecto sobre las cifras; sostiene la trazabilidad del método
S-08	Sin uso: los ingresos no percibidos por hora de indisponibilidad del telecontrol se derivan de la ficha, 190 MW de demanda media × USD 200 por MWh; el identificador se conserva	Derivación de la ficha: USD 38 000	Ficha de datos del cliente, bloque «Economía»: demanda de 120 a 275 MW	24 000	38 000	55 000	Gobierna el costo por hora y el costo al MTPD; la conclusión se mantiene en los tres escenarios
S-09	Sin uso: las compensaciones contractuales a clientes industriales son un dato de la ficha; el identificador se conserva	Dato de la ficha: USD 4 500 por hora	Ficha de datos del cliente, bloque «Operación por proceso», penalizaciones del SCADA	2 000	4 500	9 000	Efecto menor sobre el total; no cambia ninguna clasificación
S-10	Sin uso: el AV del proceso de control de red se deriva de la ficha, USD 6,0 M de margen de la energía que distribuyen las doce subestaciones más USD 3,0 M de reposición de la plataforma SCADA; el identificador se conserva	Derivación de la ficha: USD 9 000 000	Ficha de datos del cliente, bloque «Economía»: margen de 4,5 a 8,0 M y reposición de 2,0 a 4,0 M	6 500 000	9 000 000	12 000 000	Gobierna el SLE y, con él, el ALE de E.05; la justificación de los controles 12 y 13 se sostiene incluso en el mínimo
S-11	Criterio de desempate entre procesos con igual puntaje: mayor costo de indisponibilidad por hora	Aplicado a P-04 y P-02 (2,46)	Decisión del equipo registrada en acta · 13 oct 2026	—	—	—	Solo altera el orden entre dos procesos importantes
S-12	EF del evento de referencia sobre el SCADA (cifrado o manipulación con 24 h de indisponibilidad)	0,55	Criterio del dueño del proceso y costo por día · 8 oct 2026	0,40	0,55	0,70	Variable que más mueve el SLE; se somete a sensibilidad en la sección 6 y en E.05, tabla D.7
S-13	Sin uso: la duración máxima sostenible del procedimiento alterno del SCADA es un dato de la ficha; el identificador se conserva	Dato de la ficha: 12 horas con un solo relevo	Ficha de datos del cliente, bloque «Operación por proceso»; el simulacro de marzo de 2026 lo sostuvo 8 horas con relevo completo	8	12	16	Si el mínimo se confirma, el MTPD debería revisarse a la baja: es la variable que la dirección debe validar primero
S-14	Presupuesto de seguridad de 2028 y 2029 igual al de 2027	USD 480 000	Ficha de datos del cliente, bloque «Organización y presupuesto»: 480 000 aprobados para 2027; 2028 y 2029 sujetos a aprobación, entre 300 000 y 600 000	300 000	480 000	600 000	Techo del ACC de los controles; con el mínimo, el roadmap de E.10 desplaza dos iniciativas al mediano plazo

Las variables que más mueven el resultado son las que gobiernan la conclusión, y son las que el informe ejecutivo nombra.

4. Puntos únicos de falla identificados

Cada punto único de falla se registra con su proceso y pasa al informe ejecutivo. Los del caso resuelto de la Guía del Estudiante son la segmentación laxa entre la red administrativa y la médica y la ausencia de inventario de los dispositivos médicos conectados; cada equipo identifica al menos dos en su propia empresa.

N.º	Punto único de falla	Proceso afectado	Consecuencia si falla	Alternativa propuesta	Prioridad
SPOF-01	Un solo ingeniero con credenciales y conocimiento de administración del SCADA	P-01, P-03	Sin capacidad de recuperar la plataforma dentro del RTO de 2 horas; dependencia del soporte del fabricante con respuesta de 8 horas	Documentar la configuración, formar a un segundo ingeniero y contratar respuesta de 4 horas con el fabricante	Alta
SPOF-02	Centro de control de red sin redundancia geográfica ni puesto de mando equipado	P-01, P-03	La indisponibilidad de la sala deja la red sin telecontrol durante todo el evento	Equipar el puesto de mando móvil con dos HMI y enlace de radio	Alta
SPOF-03	Autenticación de los operadores dependiente del directorio corporativo de TI	P-01	Un incidente en la red de TI impide operar la red eléctrica	Cuentas locales de emergencia en sobre sellado y autenticación independiente para el entorno OT	Alta
SPOF-04	Acceso remoto de mantenimiento del proveedor SCADA sin autenticación multifactor ni registro	P-01	Vía de entrada directa al entorno de control desde fuera de la organización	Concentrador de acceso con multifactor, aprobación por sesión y grabación	Crítica
SPOF-05	Un único concentrador de datos AMI por zona, sin reserva	P-02	Pérdida de lectura de la zona durante el ciclo, con estimación obligada	Reserva fría de concentradores y procedimiento de sustitución en 24 horas	Media
SPOF-06	Enlace único del sistema comercial con la pasarela de pagos	P-04	Cobro en línea detenido durante el evento	Segundo proveedor de pagos con conmutación manual	Media
SPOF-07	Radio troncalizado con repetidores en tres cerros, sin respaldo de energía en uno de ellos	P-01, P-03, P-06	El medio alterno del MBCO se degrada justo en la contingencia	Planta de respaldo y prueba trimestral en el repetidor descubierto	Media
SPOF-08	Respaldo de la configuración del SCADA en cinta semanal, sin copia aislada verificada	P-01	Restauración fuera del RPO de 15 minutos y del RTO de 2 horas	Respaldo diario con copia aislada e inmutable y prueba de restauración trimestral	Crítica

5. Brechas detectadas por el análisis

Una brecha es una diferencia verificada entre lo que el proceso necesita y lo que la organización tiene. Se registra con su evidencia, con el control que la cerraría y con la referencia al marco correspondiente.

Brecha	Evidencia que la sostiene	Control propuesto	Referencia CIS v8.1 o NIST CSF 2.0	Prioridad
B-01 El respaldo vigente no sostiene el RPO de 15 minutos ni el RTO de 2 horas del SCADA	Respaldo en cinta semanal, sin prueba de restauración documentada (revisión documental del 8 de octubre)	Respaldo automatizado, copia aislada e inmutable y pruebas de restauración periódicas	CIS 11.2, 11.3, 11.4, 11.5 · CSF 2.0 RC.RP	Crítica
B-02 Los puntos de conexión entre la red de TI y la red OT no atraviesan un filtro documentado	El propio perfil declara que el aislamiento no es real	Segmentación con zona intermedia y reglas aprobadas y revisadas	CIS 12.2, 12.4, 12.8 · CSF 2.0 PR.IR	Crítica
B-03 No existe inventario de los activos de la red OT ni de los concentradores AMI	Entrevista con TI/TO del 7 de octubre: el inventario cubre solo la red corporativa	Inventario de activos con descubrimiento pasivo en OT	CIS 1.1, 1.2, 1.5 · CSF 2.0 ID.AM	Alta
B-04 Sin monitoreo de seguridad en la red OT ni recolección centralizada de bitácoras	No hay herramienta de detección en OT y las bitácoras quedan en cada equipo	Detección pasiva de intrusiones en OT y centralización de bitácoras	CIS 8.2, 8.9, 13.1, 13.5 · CSF 2.0 DE.CM	Alta
B-05 El acceso remoto de proveedores carece de multifactor y de registro por sesión	Contrato de soporte revisado el 8 de octubre: acceso permanente con usuario compartido	Multifactor, cuenta nominal por técnico y grabación de sesión	CIS 6.3, 6.5, 6.7, 15.4 · CSF 2.0 PR.AA	Crítica
B-06 No hay ventana de mantenimiento ni proceso de parcheo para servidores y HMI del entorno OT	Entrevista con TI/TO: el parcheo se hace cuando el fabricante lo autoriza, sin calendario	Gestión de vulnerabilidades con ventana declarada y remediación por riesgo	CIS 7.1, 7.2, 7.5, 7.7 · CSF 2.0 ID.RA	Alta
B-07 La videovigilancia de subestaciones queda fuera del alcance con convergencia no resuelta hacia la red OT	Exclusión declarada en E.02 y confirmada en el taller del 2 de octubre	Revisión de la conexión de los equipos de video y su segmentación	CIS 12.2 · CSF 2.0 ID.AM	Media
B-08 La competencia de administración del SCADA no está documentada ni replicada	SPOF-01	Documentación de la configuración y formación de un segundo ingeniero	CIS 14.1 · CSF 2.0 GV.RR	Alta

6. Valoración con rangos: la alternativa FAIR

El análisis factorial del riesgo de la información es una taxonomía publicada por The Open Group en sus normas Open FAIR: la de taxonomía Risk Taxonomy O-RT en su versión 3.0.1 y la de análisis Risk Analysis O-RA en su versión 2.0.1, ambas de noviembre de 2021. Descompone el riesgo en la frecuencia de los eventos de pérdida y la magnitud de la pérdida, y esta última en pérdida primaria, la que sufre la organización de forma directa, y pérdida secundaria, la que proviene de la reacción de terceros: multas, litigios y respuesta de los clientes. Trabaja con rangos y

distribuciones de probabilidad en lugar de valores puntuales, lo que encaja cuando los datos históricos escasean, que es la situación de las empresas del catálogo. Esta sección se llena cuando el equipo elige explorar la alternativa.

Factor	Rango mínimo	Rango esperado	Rango máximo	Fundamento del rango
Frecuencia de eventos de pérdida	0,2 al año	0,5 al año	1,0 al año	Frecuencia de campañas de ransomware con efecto sobre entornos de tecnología de operación en el sector eléctrico de la región; el valor esperado corresponde al nivel 4 de la escala de probabilidad de E.05
Magnitud de la pérdida primaria	USD 2 600 000	USD 4 950 000	USD 8 400 000	AV entre USD 6,5 y 12 millones con EF entre 0,40 y 0,70 (AV derivado de la ficha y supuesto S-12)
Magnitud de la pérdida secundaria	USD 150 000	USD 420 000	USD 1 100 000	Sanción regulatoria, compensaciones a clientes industriales y costo de comunicación de crisis
Magnitud total de la pérdida	USD 2 750 000	USD 5 370 000	USD 9 500 000	Suma de las dos anteriores en cada escenario

Comparación con el resultado obtenido por el método de valores puntuales, y criterio del equipo sobre cuál conviene en este caso:

La valoración con rangos se incluye porque el supuesto S-12 (factor de exposición) es el que más mueve el resultado. La conclusión del análisis —que el tratamiento de los riesgos sobre el entorno SCADA se justifica económicamente— se mantiene en los tres escenarios, y así lo declara el informe ejecutivo de BIA_P07.

7. Glosario de los campos de esta plantilla

Término	Definición
Supuesto declarado	Estimación que sostiene una cifra del análisis, registrada con su origen y su fecha.
Análisis de sensibilidad	Variación de cada supuesto en escenarios mínimo, esperado y máximo para observar cuánto se mueve el resultado.
Pérdida primaria	Pérdida que la organización sufre de forma directa por el evento.
Pérdida secundaria	Pérdida que proviene de la reacción de terceros: multas, litigios y respuesta de los clientes.
Brecha	Diferencia verificada entre lo que el proceso necesita y lo que la organización tiene.

ESEN

CIBERSEGURIDAD

Informe ejecutivo del análisis de impacto

El documento que la dirección lee, discute y firma

Ejemplo resuelto de cátedra · Nexo Crítico Consultores · Energía Nacional S.A. de C.V. (ENSA)

Análisis de Impacto en el Negocio · Plantilla 07 de 07

ISO 22301:2019 · ISO/TS 22317:2021 · NIST SP 800-34 Rev. 1

Docente: Ing. Héctor Cuchilla

ESEN – CIBERSEGURIDAD – CICLO 03 – 2026

Tabla de contenidos

1. Identificación del trabajo..... 3
2. Resumen ejecutivo..... 3
3. Alcance y método..... 4
4. Procesos críticos priorizados y sus métricas de tiempo..... 5
5. Costo de la indisponibilidad..... 5
6. Puntos únicos de falla y brechas que exigen decisión..... 6
7. Frontera con el análisis de riesgos..... 6
8. Justificación económica del control, en cinco pasos..... 7
9. Costo anual del control (ACC)..... 7
10. Retorno de la inversión en seguridad (ROSI)..... 8
11. Análisis de sensibilidad en tres escenarios..... 8
12. Recomendaciones y decisión solicitada a la dirección..... 9
13. Aprobación..... 10
14. Referencias..... 10

Ejemplo resuelto de cátedra · anexo 7 de 7. Es el documento que la dirección de ENSA lee, discute y firma.

1. Identificación del trabajo

Esta plantilla se llena por equipo y sobre la empresa que el equipo tiene asignada en el catálogo del Proyecto Final. El caso resuelto que la Guía del Estudiante desarrolla usa la Red Hospitalaria Metropolitana; cada equipo aplica el mismo método a su propia empresa.

Campo	Contenido
Empresa del catálogo del Proyecto Final	Energía Nacional S.A. de C.V. (ENSA), perfil n.° 4
Sector y tamaño declarados en el perfil	Energía y servicios públicos · mediana, 550 empleados
Equipo (número y nombre)	Equipo 04 · Nexo Crítico Consultores
Integrantes	Seis integrantes con los cinco roles cubiertos
Analista responsable de esta plantilla	Alejandra Beltrán Rivas, consultora líder
Fecha de elaboración	15 de octubre de 2026
Versión del documento	v1.1 · viernes 23 de octubre de 2026, con las secciones 8 a 11 entregadas junto con E.05

2. Resumen ejecutivo

Una página como máximo, escrita para la dirección. Contiene la exposición de la organización expresada en dinero por unidad de tiempo, el plazo de tolerancia que el propio negocio declaró, los hallazgos que exigen decisión y la recomendación con su costo.

El análisis de impacto evaluó diez procesos de ENSA y confirmó dos como críticos: la operación de la red de control (SCADA/OT) y la gestión de interrupciones (OMS). El sistema comercial y de facturación y la medición inteligente (AMI), que el perfil declara críticos, resultaron importantes con 2,46: a las veinticuatro horas ninguna de sus calificaciones pasa de 3 y su impacto crece en días. La distancia entre el telecontrol y los procesos comerciales es la conclusión que gobierna las decisiones: el telecontrol tolera cuatro horas de interrupción, mientras que la facturación tolera setenta y dos. Cada hora sin telecontrol cuesta USD 62 000 en el escenario de temporada de lluvias, y al alcanzar el período máximo tolerable la pérdida asciende a USD 248 000.

El análisis identificó ocho puntos únicos de falla y ocho brechas. Cuatro exigen decisión inmediata: el respaldo del sistema SCADA no permite cumplir los objetivos de recuperación declarados; los puntos de conexión entre la red de TI y la red OT no atraviesan un filtro documentado, tal como el propio perfil reconoce al describir un aislamiento que no es real; el acceso remoto del proveedor del sistema de control opera sin autenticación multifactor ni registro; y no existe inventario ni monitoreo de seguridad en la red OT.

El tratamiento del riesgo de mayor exposición —compromiso del entorno SCADA por propagación desde la red de TI — se justifica económicamente con holgura: la pérdida anual esperada asciende a USD 2 475 000 y el conjunto de controles propuesto la reduce a USD 990 000 con un costo anual de USD 186 000, lo que produce un retorno de 698 %. La recomendación se mantiene en los tres escenarios de sensibilidad, incluido el más conservador.

3. Alcance y método

Campo	Contenido
Procesos incluidos en el análisis	Los diez procesos del censo de BIA_P01: los cuatro que el perfil declara críticos y seis de soporte con efecto directo sobre ellos
Procesos excluidos y por qué	Red inalámbrica de invitados, videovigilancia de subestaciones y equipos de medición en poder del cliente, con la justificación declarada en E.02; la videovigilancia se registra como brecha B-07 por su convergencia no resuelta con la red OT
Período de levantamiento	Del 29 de septiembre al 14 de octubre de 2026
Medios de levantamiento empleados	Entrevista estructurada con los cinco dueños de proceso, cuestionario estandarizado, taller con áreas interdependientes, revisión documental de contratos y bitácoras, validación firmada y aprobación de la dirección
Personas entrevistadas y áreas participantes	Gerencia General, Operaciones de Red, Técnica, Comercial, Finanzas y TI/TO; dos operadores del centro de control y un ingeniero de subestaciones
Método de valoración empleado	Cuantitativo para las categorías financiera y operativa, cualitativo para la reputacional y la de seguridad de las personas, y semicuantitativo en la priorización ponderada
Escenario temporal usado (período pico considerado)	Temporada de lluvias y tormentas eléctricas, de mayo a octubre, con factor de agravamiento de 2,2 × en fallas simultáneas y 1,6 × en costo por hora

4. Procesos críticos priorizados y sus métricas de tiempo

Orden	Proceso	Clase	MTPD	RTO	WRT	RPO	MBCO declarado
1	P-01 Operación de la Red de Control (SCADA/OT)	Crítico	4 h	2 h	1,5 h	15 min	Operación manual de las doce subestaciones principales con radio troncalizado
2	P-03 Sistema de Gestión de Interrupciones (OMS)	Crítico	8 h	4 h	3 h	1 h	Despacho de cuadrillas con planillas impresas y avisos por el centro de contacto
3	P-09 Gestión de TI corporativa	Importante	24 h	8 h	4 h	4 h	Autenticación local de emergencia y correo en modo básico
4	P-06 Gestión de campo y cuadrillas con GIS	Importante	48 h	24 h	8 h	8 h	Órdenes de trabajo en planilla impresa con despacho por radio
5	P-04 Sistema Comercial y de Facturación	Importante	72 h	24 h	24 h	4 h	Facturación con lectura estimada del ciclo anterior para el 100 % de los clientes regulados
6	P-02 Gestión de Medición Inteligente (AMI)	Importante	48 h	24 h	12 h	6 h	Lectura manual del 15 % de clientes de mayor consumo y estimación para el resto

Comprobación de coherencia de todas las fichas: RTO + WRT ≤ MTPD. Fichas que la superan: _____ de _____.

En los seis procesos se cumple la comprobación RTO + WRT ≤ MTPD. El margen más estrecho es el del proceso de control de red: media hora sobre cuatro.

5. Costo de la indisponibilidad

Proceso	Costo por hora	Costo por día	Costo al alcanzar el MTPD	Supuesto principal
P-01 Operación de la Red de Control (SCADA/OT)	USD 62 000	USD 1 488 000	USD 248 000 (4 h)	Derivación de la ficha: ingresos no percibidos de USD 38 000 por hora (190 MW × USD 200 por MWh)
P-03 Sistema de Gestión de Interrupciones (OMS)	USD 18 500	USD 444 000	USD 148 000 (8 h)	Penalización por tiempo de restauración e improductividad de cuadrillas
P-04 Sistema Comercial y de Facturación (importante)	USD 7 400	USD 177 600	USD 532 800 (72 h)	Facturación diferida del ciclo, recuperable con cobro posterior

Proceso	Costo por hora	Costo por día	Costo al alcanzar el MTPD	Supuesto principal
P-02 Gestión de Medición Inteligente (AMI) (importante)	USD 2 900	USD 69 600	USD 139 200 (48 h)	Lectura manual y estimación del consumo del ciclo

El MTPD se expresa en horas transcurridas y el costo acumula solo durante la ventana de operación del proceso.

El costo por hora del proceso de control de red es 8,4 veces el del sistema comercial; el costo al alcanzar el período máximo tolerable, en cambio, es mayor en el sistema comercial, porque su MTPD es dieciocho veces más largo. La dirección decide sobre las dos cifras: la primera ordena la urgencia de la recuperación y la segunda, la magnitud del daño acumulado.

6. Puntos únicos de falla y brechas que exigen decisión

Hallazgo	Proceso afectado	Consecuencia	Acción propuesta	Costo estimado
SPOF-08 / B-01 · Respaldo semanal en cinta, sin copia aislada ni prueba de restauración	P-01, P-03	Recuperación fuera del RPO de 15 minutos y del RTO de 2 horas	Respaldo diario con copia aislada e inmutable y prueba de restauración trimestral	USD 74 000 anuales
B-02 · Puntos de conexión TI–OT sin filtro documentado	P-01, P-03	Propagación directa de un incidente de TI al entorno de control	Segmentación con zona intermedia, reglas aprobadas y revisión trimestral	USD 118 000 anuales
SPOF-04 / B-05 · Acceso remoto del proveedor sin multifactor ni registro	P-01	Entrada directa al entorno de control desde fuera de la organización	Concentrador de acceso con multifactor, aprobación por sesión y grabación	USD 96 000 anuales
B-03 / B-04 · Sin inventario ni monitoreo de la red OT	P-01, P-02	Intrusión indetectable e imposibilidad de investigar	Inventario con descubrimiento pasivo y sonda de detección en OT	USD 68 000 anuales
SPOF-01 / B-08 · Un solo ingeniero con competencia de administración del SCADA	P-01, P-03	Recuperación dependiente de una persona y del soporte del fabricante	Documentación de la configuración, formación de un segundo ingeniero y contrato de respuesta en 4 horas	USD 32 000 anuales
SPOF-02 · Centro de control sin redundancia ni puesto de mando equipado	P-01, P-03	Pérdida total del telecontrol si la sala queda indisponible	Equipar el puesto de mando móvil con dos estaciones y enlace de radio	USD 45 000, inversión única

7. Frontera con el análisis de riesgos

Lo que este informe entrega como resultado del BIA: la lista priorizada de procesos, los objetivos de tiempo, el costo de la interrupción por unidad de tiempo, y el valor del activo con su factor de exposición, de donde sale la pérdida esperada por evento único.

Lo que corresponde al análisis de riesgos: la tasa anualizada de ocurrencia (ARO) y la pérdida anual esperada (ALE = SLE × ARO), conforme a NIST SP 800-30 Rev. 1, porque ambas requieren estimar la probabilidad de la amenaza. El BIA responde qué pasa si ocurre; el análisis de riesgos responde con qué frecuencia ocurrirá.

El análisis de impacto entrega el valor del proceso, el factor de exposición y la pérdida por evento único. La frecuencia con que ese evento ocurre no es una pregunta del análisis de impacto: depende de la amenaza, de la exposición y de los controles existentes, y se estima en la matriz de riesgos del entregable E.05. Allí se calcula la tasa anualizada de ocurrencia, la pérdida anual esperada y el retorno de cada control, con los valores de pérdida por evento único que este informe entrega: USD 4 950 000 para el proceso de control de red, USD 1 300 000 para la gestión de interrupciones, USD 1 395 000 para el sistema comercial y USD 480 000 para la medición inteligente, dos procesos importantes que conservan su valoración, y USD 105 000 por la exposición de los datos personales de los clientes en P-04 y en P-05.

8. Justificación económica del control, en cinco pasos

En el Proyecto Final, las secciones 8 a 11 se marcan «se completa en E.05» en la entrega del hito H2 y se completan en la versión 1.1 de este informe, que se entrega junto con E.05.

Paso	Resultado	Cómo se obtuvo y con qué fundamento
1. ALE actual, sin control adicional (línea base de riesgo)	USD 2 475 000	SLE de USD 4 950 000 (BIA_P02, sección 9) por una tasa anualizada de ocurrencia de 0,5, que corresponde al nivel 4 de probabilidad de la escala de E.05
2. Efectividad estimada del control (sobre el SLE o sobre el ARO)	Reducción de la tasa de 0,5 a 0,2	La segmentación con zona intermedia elimina la propagación directa desde la red de TI y la detección pasiva reduce el tiempo de permanencia del atacante: dos niveles menos de probabilidad en la escala declarada
3. ALE con el control operando	USD 990 000	SLE de USD 4 950 000 por la tasa de 0,2
4. Beneficio (diferencia entre ambos ALE)	USD 1 485 000	2 475 000 − 990 000
5. Costos totales del control (ACC)	USD 186 000 anuales	Suma de las tres familias de gasto de la sección 9

La efectividad se apoya en especificaciones técnicas y estudios, no en la impresión del proveedor.

9. Costo anual del control (ACC)

Omitir cualquiera de las tres familias de gasto infla el retorno aparente y produce decisiones que el presupuesto desmiente al año siguiente.

Familia de gasto	Componentes que incluye	Monto anual
Adquisición	Dos cortafuegos industriales para la zona intermedia y una sonda de detección pasiva para la red OT, con implantación; inversión de USD 480 000 anualizada sobre cinco años de vida útil	USD 96 000
Operación	Media plaza de analista de seguridad de tecnología de operación, revisión trimestral de reglas y atención de alertas	USD 62 000
Mantenimiento	Soporte y actualizaciones del fabricante, afinamiento de firmas y capacitación del personal de operación	USD 28 000
Total ACC		**USD 186 000**

10. Retorno de la inversión en seguridad (ROSI)

ROSI = (Beneficio − ACC) ÷ ACC, expresado en porcentaje.

Beneficio: _____ − ACC: _____ = Beneficio neto: _____

Beneficio neto ÷ ACC = ROSI: _____ %

El indicador permite comparar controles entre sí y ordenar el gasto, y su valor depende por completo de la calidad de las estimaciones que lo alimentan.

ROSI = (Beneficio − ACC) ÷ ACC = (1 485 000 − 186 000) ÷ 186 000 = **698 %**. El control se justifica porque su costo anual equivale al 12,5 % de la reducción de pérdida esperada que produce, y porque el costo de una sola hora de indisponibilidad del telecontrol, USD 62 000, cubre un tercio del costo anual del control.

11. Análisis de sensibilidad en tres escenarios

Escenario	ARO	ALE	Beneficio	ACC	ROSI	La recomendación se mantiene
Mínimo	0,2	USD 990 000	USD 594 000	USD 186 000	219 %	Sí
Esperado	0,5	USD 2 475 000	USD 1 485 000	USD 186 000	698 %	Sí
Máximo	1,0	USD 4 950 000	USD 2 970 000	USD 186 000	1 497 %	Sí

Conclusión sobre la robustez de la recomendación. Si cambia de signo al variar un solo supuesto, decirlo con esas palabras y nombrar el supuesto del que depende:

La conclusión es robusta: el control se justifica incluso con la frecuencia más baja del rango y con el factor de exposición mínimo del supuesto S-12. La variable que sí exige validación de la dirección es otra: la duración máxima sostenible del procedimiento alterno (dato de la ficha: 12 horas con un solo relevo, en un rango de 8 a 16), porque si el valor real se acerca a las ocho horas del simulacro, el período máximo tolerable de cuatro horas debe revisarse a la baja y el objetivo de recuperación se vuelve más exigente.

12. Recomendaciones y decisión solicitada a la dirección

N.°	Recomendación	Proceso o hallazgo que la origina	Costo	Decisión solicitada
1	Implantar el respaldo diario del entorno SCADA con copia aislada e inmutable y prueba de restauración trimestral	B-01 / SPOF-08	USD 74 000 anuales	Aprobar e iniciar en el primer trimestre
2	Segmentar los puntos de conexión entre la red de TI y la red OT con zona intermedia y reglas aprobadas	B-02	USD 118 000 anuales	Aprobar e iniciar en el primer trimestre
3	Someter el acceso remoto de proveedores a multifactor, cuenta nominal y grabación de sesión	B-05 / SPOF-04	USD 96 000 anuales	Aprobar y renegociar el contrato de soporte
4	Inventariar los activos de la red OT con descubrimiento pasivo y desplegar detección de intrusiones en OT	B-03 / B-04	USD 68 000 anuales	Aprobar para el segundo semestre
5	Documentar la configuración del SCADA, formar un segundo ingeniero y contratar respuesta del fabricante en 4 horas	SPOF-01 / B-08	USD 32 000 anuales	Aprobar e iniciar de inmediato, por su bajo costo
6	Equipar el puesto de mando móvil como centro de control alterno	SPOF-02	USD 45 000, inversión única	Decidir en la revisión trimestral
7	Validar con la Gerencia de Operaciones de Red la duración máxima sostenible del procedimiento alterno y, si procede, revisar el MTPD	Ficha de datos del cliente, procedimiento alterno del SCADA	Sin costo directo	Instruir la validación antes del cierre del ejercicio

13. Aprobación

Rol	Nombre y cargo	Fecha	Firma
Analista responsable del BIA	Alejandra Beltrán Rivas, consultora líder · Nexo Crítico Consultores	15 de octubre de 2026	(firma)
Responsable de seguridad de la información	Ing. Karla Beatriz Vásquez, Jefa de Seguridad de la Información	15 de octubre de 2026	(firma)
Dirección general	Ing. Óscar Mauricio Handal, Gerente General	16 de octubre de 2026	(firma)

14. Referencias

- ISO 22301:2019 — Seguridad y resiliencia. Sistemas de gestión de la continuidad del negocio. Requisitos.
- ISO/TS 22317:2021 — Directrices para el análisis de impacto en el negocio. Segunda edición, confirmada vigente en 2025.
- NIST SP 800-34 Rev. 1 — Guía de planificación de contingencia para sistemas de información federales.
- NIST SP 800-30 Rev. 1 — Guía para la conducción de evaluaciones de riesgo.
- NIST CSF 2.0 (2024) — Marco de ciberseguridad, funciones de gobernar, identificar y recuperar.
- CIS Controls v8.1 (2024) — Controles de inventario de activos y de recuperación de datos.
- The Open Group — Risk Taxonomy (O-RT) versión 3.0.1 y Risk Analysis (O-RA) versión 2.0.1, noviembre de 2021.